

PIEDPIN

Let's try CISSP!

なぜCISSPを学ぶのか

- ✓ CISSP(Certified Information Systems Security Professional)とは、世界標準の**セキュリティ・プロフェッショナル認定**です。
- ✓ (ISC)²（国際情報システムセキュリティ認証コンソーシアム、International Information Systems Security Certification Consortium）が認定を行っています。
- ✓ 情報セキュリティ専門家が共通言語として利用している『(ISC)² CISSP CBK』を理解している者に与えられる資格です。
- ✓ 2004年6月に、米国規格協会（ANSI）より**ISO/IEC17024**の認証を受け、信頼度がより高くなりました。（https://japan.isc2.org/cissp_about.html）
- ✓ 2022年7月1日現在、日本のCISSPは**3,699**人です。

(ISC)² が展開する資格ソリューション



国際的に認められた情報セキュリティ・プロフェッショナル認定資格です。米国規格協会（ANSI）よりISO/IEC17024の認証を受けた。



ベンダーフリー・カントリーフリーの情報セキュリティの資格です。情報セキュリティに従事しないが、組織を理解し、適切なコミュニケーションを行う。



クラウドサービスを安全に利用するために必要な知識を体系化した資格です。



ソフトウェアの脆弱性に端を発したセキュリティインシデントの増加や、政府や重要インフラにおけるセキュアなソフトウェアニーズに対応する資格です。

(ISC)² CISSP CBK ドメイン



ドメイン 1
セキュリティとリスク
マネジメント



ドメイン 2
資産のセキュリティ



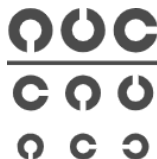
ドメイン 3
セキュリティアーキ
テクチャとエンジニ
アリング



ドメイン 4
通信とネットワー
クのセキュリティ



ドメイン 5
アイデンティティと
アクセスの管理



ドメイン 6
セキュリティの評
価とテスト



ドメイン 7
セキュリティの運用



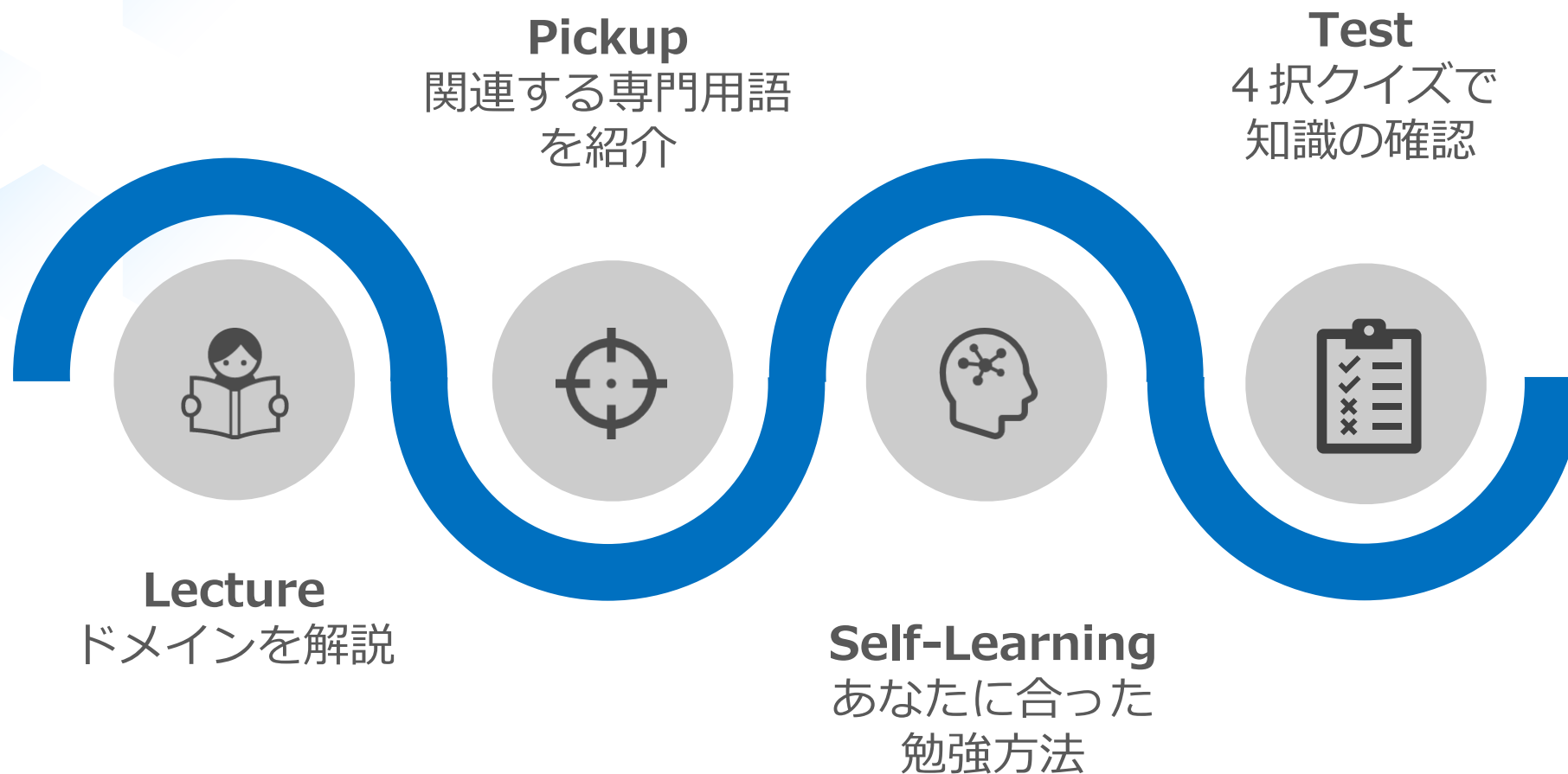
ドメイン 8
ソフトウェア開発
セキュリティ

あなたのゴールと本レッスンの内容

- ✓ 情報セキュリティ初心者のために設計されたCISSP講座
経験者からすると“当たり前”と感じる内容も含まれます。
- ✓ 本レッスンの対象は、CBKのドメイン 5 です。
他のドメインのレッスンは対象外となります。
- ✓ CISSP合格のためのアップグレードが必要です。
現代のセキュリティの関心、流行、考え方を織り込みます。



レッスンの流れ



ドメイン別試験比重



ドメイン 1
セキュリティと
リスクマネジメント

16%



ドメイン 2
資産のセキュリティ

10%



ドメイン 3
セキュリティアーキテク
チャとエンジニアリング

13%



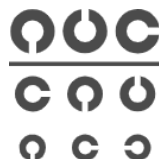
ドメイン 4
通信とネットワーク
のセキュリティ

13%



ドメイン 5
アイデンティティと
アクセスの管理

13%



ドメイン 6
セキュリティの評価
とテスト

12%



ドメイン 7
セキュリティの運用

13%



ドメイン 8
ソフトウェア開発
セキュリティ

10%



認証／認可の設計

認証／認可の設計

IAAA

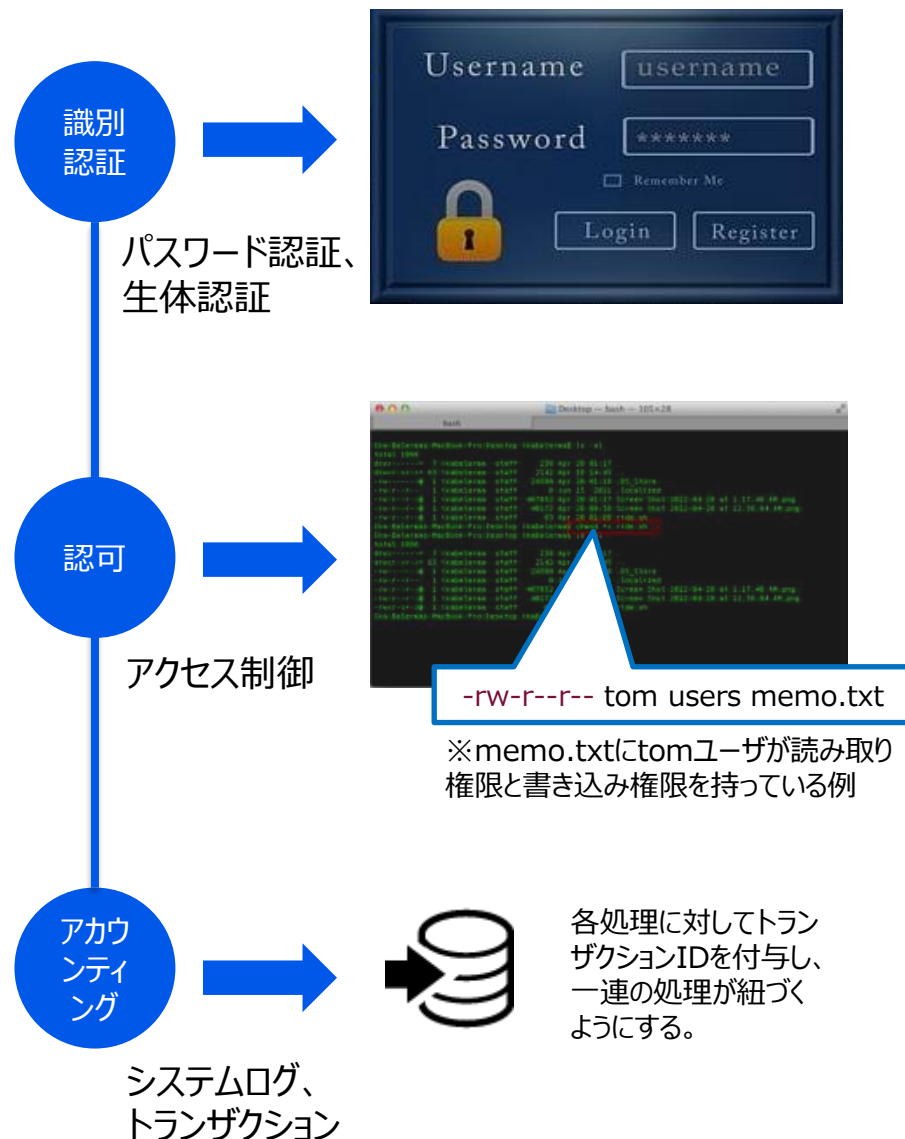
● AAAプロトコル (IAAA)

識別 (Identity)

- 識別は、ユーザーやデバイスが「誰であるか」を名乗るプロセスです。例えば、ログイン画面で入力された、ユーザー名がシステムのデータベースの存在するかを確認するプロセスが識別にあたります。
- 識別には、ユーザーIDやユーザー名などの一意な識別子が使われます。

認証 (Authentication)

- 認証は、識別されたユーザーやデバイスが本当にその本人であるかどうかを確認するプロセスです。
- パスワード、指紋認証、フェイスID、多要素認証 (MFA) が一般的に用いられます。



認証／認可の設計

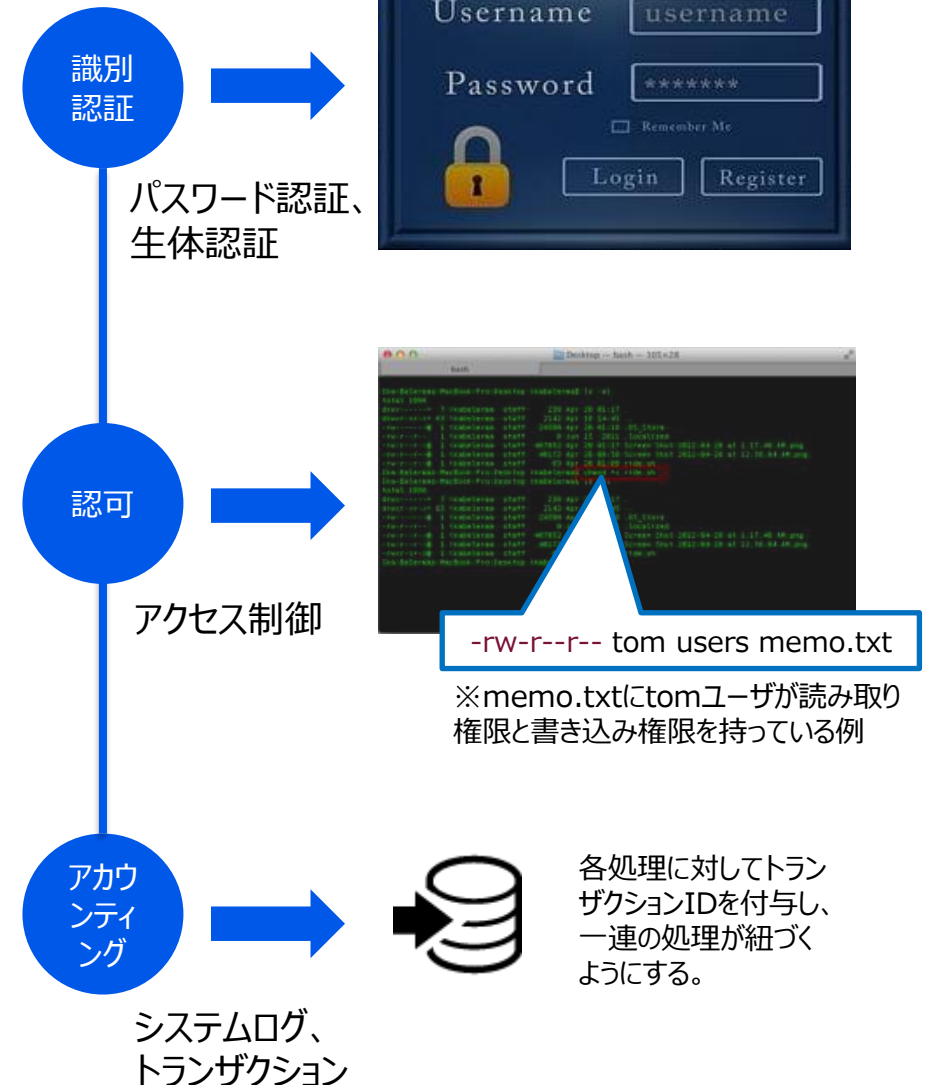
IAAA

● AAAプロトコル (IAAA) 認可 (Authorization)

- 認可は、認証済みのユーザーやデバイスが、システム内のどのリソースにどのレベルでアクセスできるかを決定するプロセスです。
- 認可には、ロールベースのアクセス制御 (RBAC) などの手法が使用されます。

アカウントिंग (Accounting)

- アカウントिंगは、ユーザーやデバイスのアクティビティを追跡し、ログを記録するプロセスです。
- アカウントिंगは監査やセキュリティ対策、問題のトラブルシューティングに役立ちます。



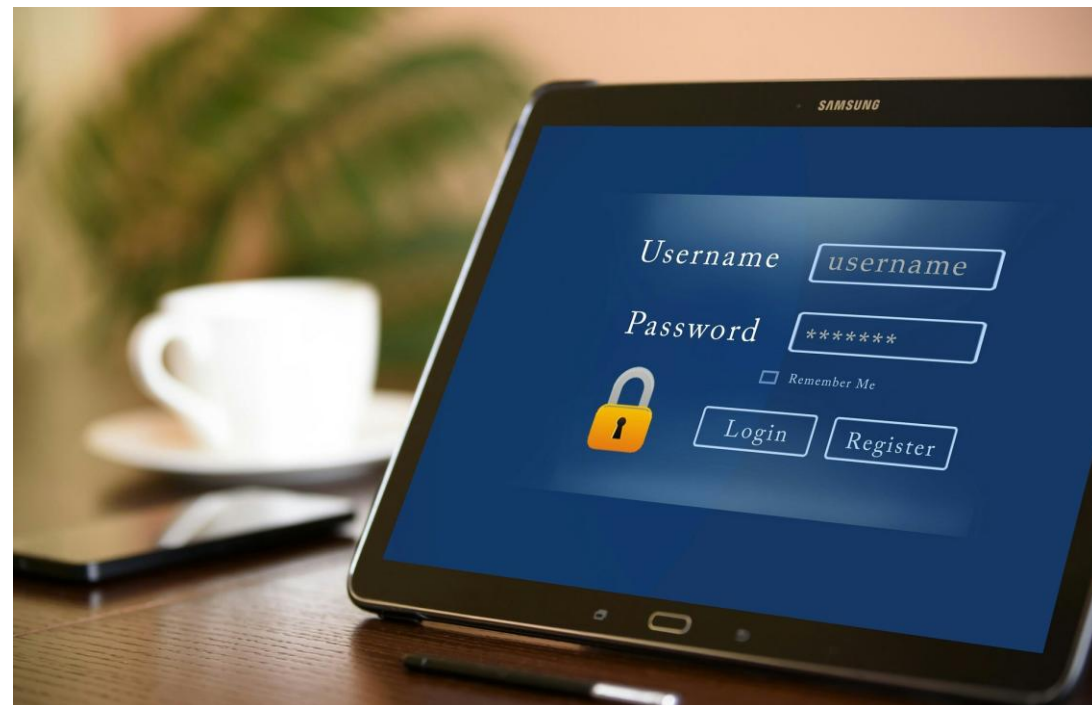
認証／認可の設計

IAAA

● 認証タイプ

Type1 (Something You Know)

- ユーザーだけが知っている記憶情報で認証を行う方法です。
- 簡単に設定できる一方で、盗み見やフィッシング詐欺により第三者に漏れるリスクがあります。
- 例：パスワード認証、PIN認証、秘密の質問



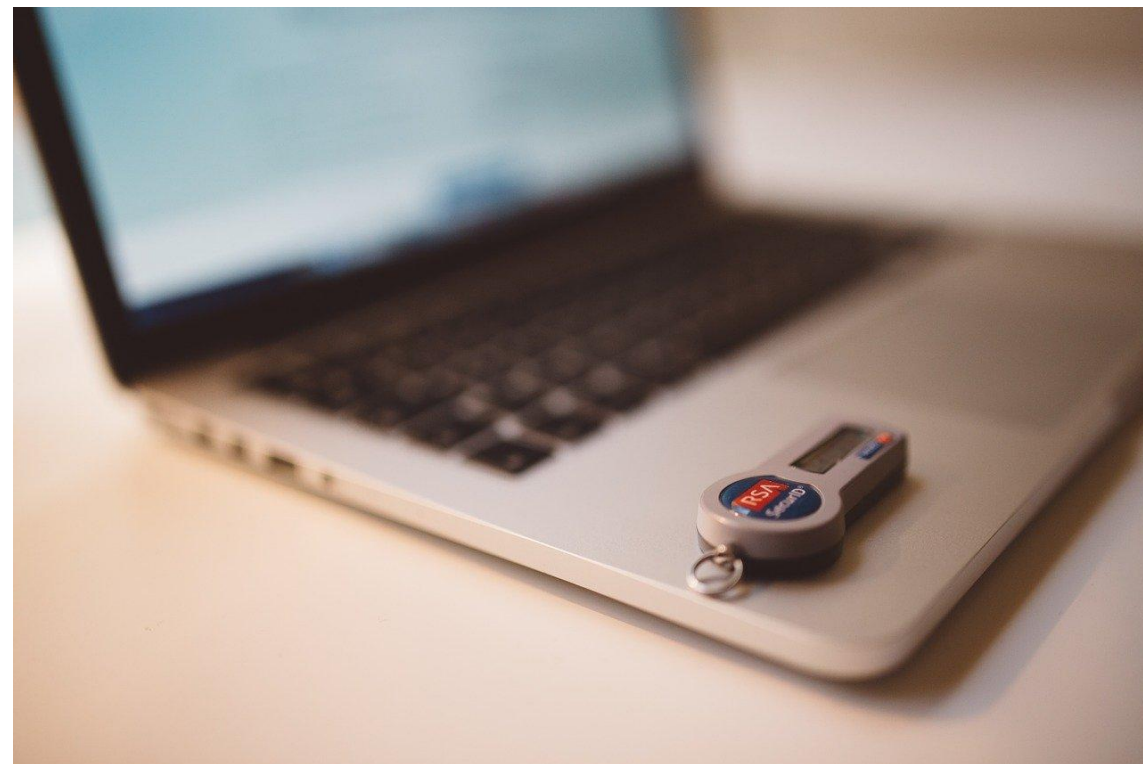
認証／認可の設計

IAAA

● 認証タイプ

Type2 (Something You Have)

- ユーザーが持っている物理的なデバイスを使用して認証する方法です。
- 所有物を利用するため、Type 1よりも安全性が高まりますが、紛失や盗難のリスクがあります。
- 例：スマートフォン（SMSによるコード受信や認証アプリなど）、物理的なトークン（ハードウェアトークン、スマートカードなど）。



認証／認可の設計

IAAA

● 認証タイプ

Type3 (something you are)

- ユーザーの生体情報（バイオメトリクス）を利用して認証する方法です。
- ユーザーが「何を持っているか」や「何を知っているか」ではなく、ユーザー自身の身体的特徴を利用するため、個人に固有であり、高いセキュリティを提供します。しかし、デバイスによっては、誤認や精度に差が出てしまう特性もあります。
- 例：指紋認証、顔認証、虹彩スキャン、声紋認証など。



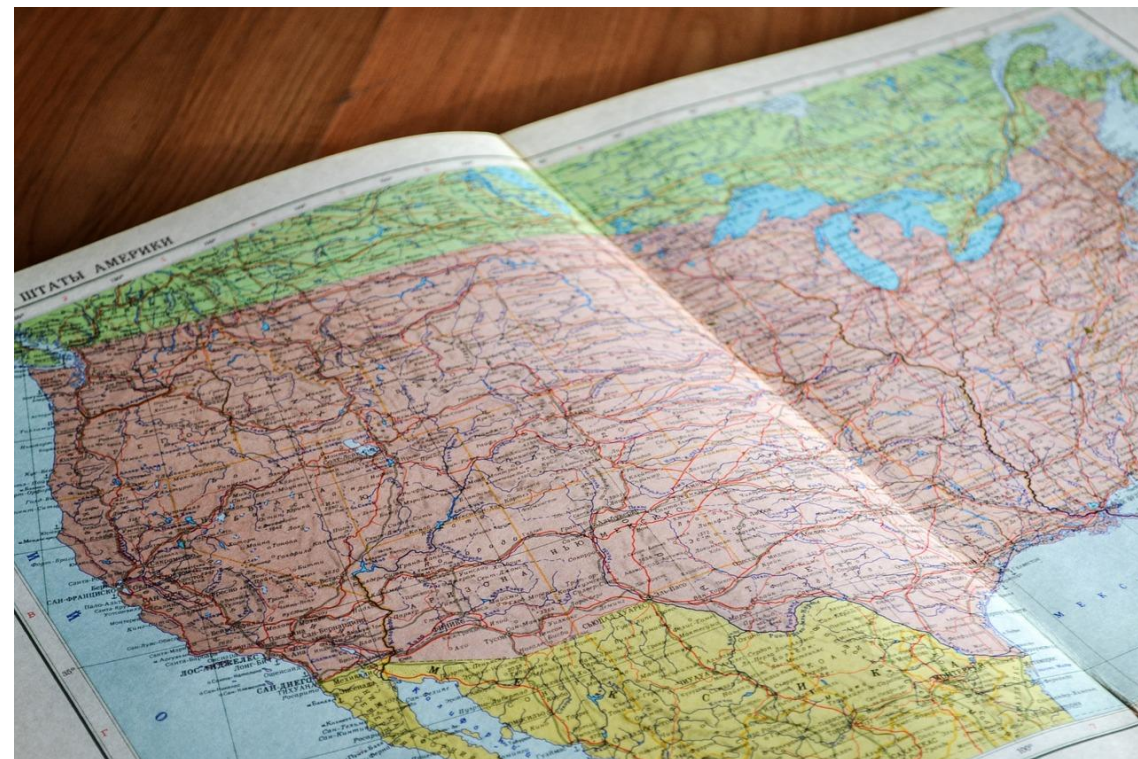
認証／認可の設計

IAAA

● 認証タイプ

Type4 (Somewhere You Are)

- ユーザーの地理的位置情報や接続元の場所を認証に用いる方法です。
- 特定の場所でのみ認証を許可することで、他の場所からの不正アクセスを防ぎます。ただし、VPNやプロキシを使用して位置を偽装されるリスクもあります。
- 例：GPSデータ、IPアドレス、Wi-Fi接続情報、または特定の位置（オフィス内など）からのアクセス認証。



認証／認可の設計

IAAA

● 認証タイプ

Type5 (Something You Do)

- ユーザーの独特な行動やパターンを認証に利用する方法です。
- 行動パターンはユーザーによって異なるため、認証方法として利用できます。このような行動認証は、時間の経過とともにパターンを学習し、個々のユーザーを識別することが可能です。
- 例：キーストローク（タイピングのリズムや速度）、マウスの動かし方、特定のジェスチャーなど。



認証／認可の設計

多要素認証

●多要素認証（MFA、Multi-Factor Authentication）

- 多要素認証とは、異なる認証タイプを組み合わせで利用することです。
- 同じ認証タイプを2回呼び出しても、多要素認証にはなりません。この場合、単に多段認証と呼ばれます。
- クレジットカードに利用されている認証では、クレジットカードの所持（Type2）とPIN（Type1）の組み合わせであり、多要素認証となります。

認証タイプ		内容
Type1	something you know	記憶による認証です。
Type2	something you have	所持物による認証です。
Type3	something you are	身体・生体による認証です。
Type4	somewhere you are	位置情報による認証です。
Type5	something you do	行動による認証です。

認証／認可の設計

登録、証明、IDの確立

●アカウントの登録

- ・ 経歴確認などのクリアランス後に、システムにアカウントをシステムに登録し、有効化します。
- ・ アカウントの情報には、本人性を担保する必要があります。例えば、メールOTP認証が完了した上で登録されたメールアドレスは、本人性があるといえます。

ユーザー？アカウント？クライアント？

ユーザーとは、システムを利用する人やエンティティです。アカウントとは、ユーザーがサービスにアクセスするための認証情報です。クライアントとは、ユーザーがシステムにアクセスするための端末やアプリケーションです。つまり、「あなた（ユーザー）はUdemyサービスに会社のメールアドレスでUdemyにアカウント登録しました。私はPC（クライアント）やスマホ（クライアント）から利用しています。」



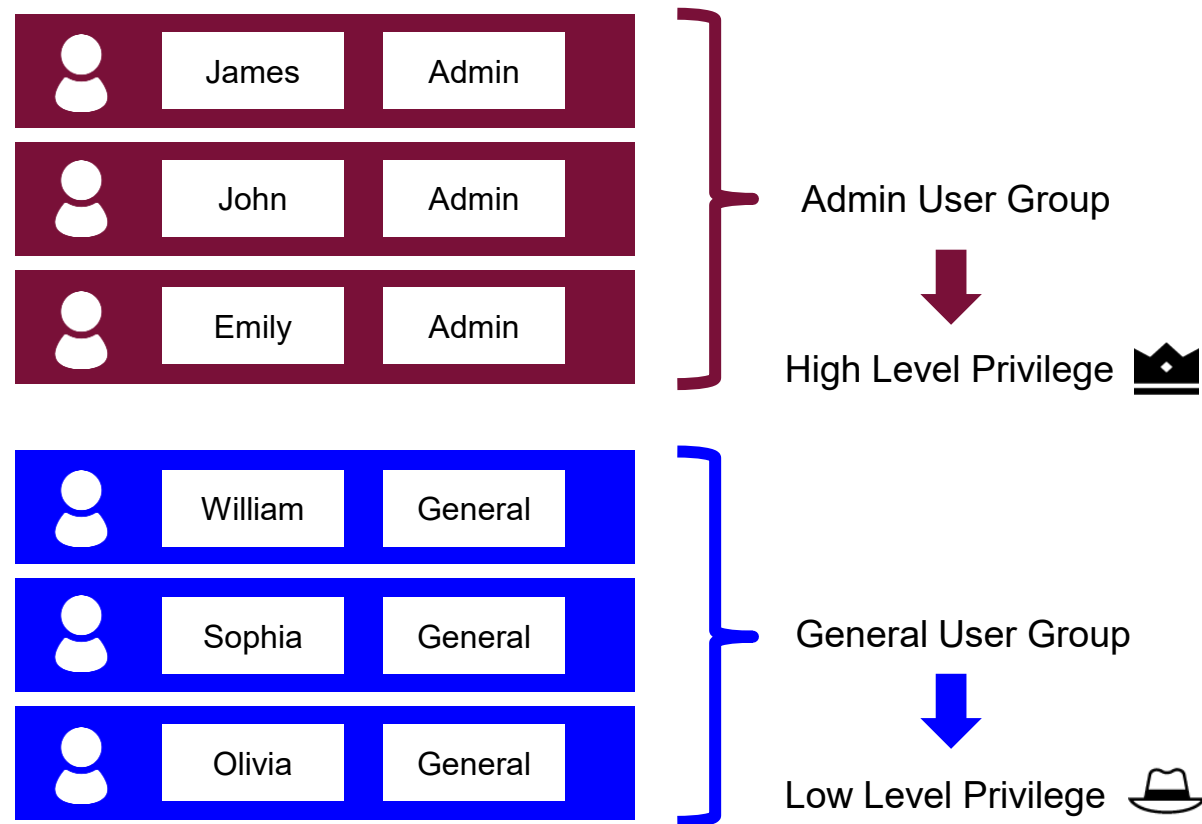
アカウント情報項目	例
内部ID	任意の値
識別情報	メールアドレス、従業員番号
認証情報	パスワード
ユーザー種別	ロール、役職、検証済み

認証／認可の設計

グループと役割

● グループを使ったアクセス権限管理

- アクセス管理におけるグループ管理は、複数のユーザーに対して共通のアクセス権や設定を一括で適用するための重要な手法です。
- 特に大規模な組織では、グループ管理により効率的なアクセス制御とセキュリティ管理が実現します。

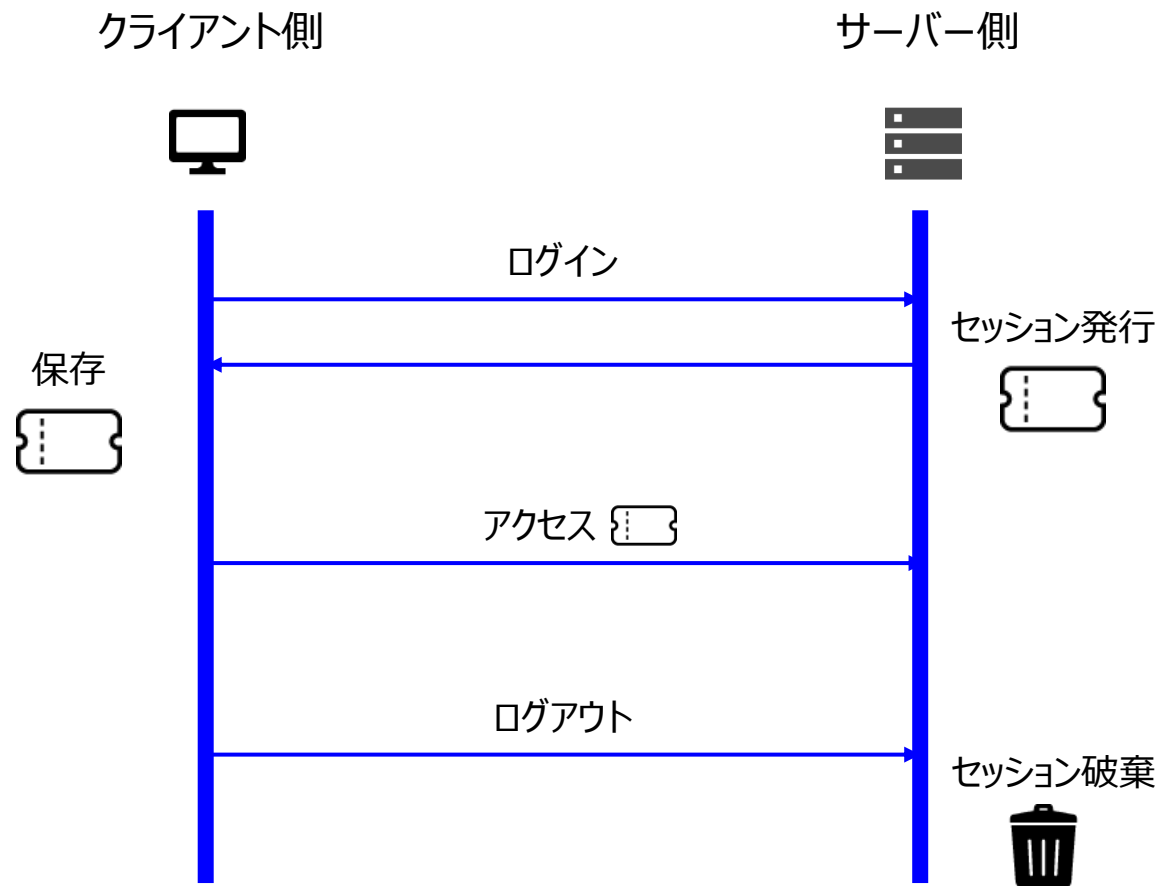


認証／認可の設計

セッション管理

●セッション管理

- 認証に成功すると、ログイン状態を示すためにセッションが発行されます。
- ログイン後は、認証情報を送る代わりにセッションをサーバーに送付します。
- 例えば、ブラウザで利用するWebアプリの場合には、セッションはCookieという形で保存されます。
- セッションIDが一致している場合に、「ログインしている状態」とであると判断されます。
- セッションIDが盗まれると成りすまされます。そのため、ログアウトや一定時間がたつと、セッションIDは破棄されます。



認証／認可の設計

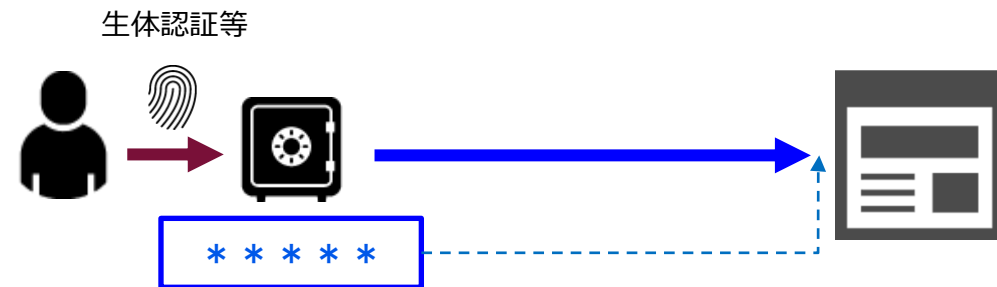
クレデンシャル管理システム

● クレデンシャル管理システム

- クレデンシャル情報とは、システムやアプリケーションに対するユーザー認証を行うために必要な情報のことを指します。例えば、パスワードです。
- ユーザーが自分自身であることを証明し、アクセスを許可するための「資格情報」とも呼ばれます。
- クレデンシャル情報は、サービス提供するシステム内部ではKey Vaultサービス、我々一般ユーザーでもパスワード管理ソフトウェアなどと呼ばれるサービスとして展開しています。



長いパスワードを覚える自信がない



パスワード保管庫にて、複雑なパスワードを管理し、
生体認証でそのパスワードを呼び出す。



サービス連携

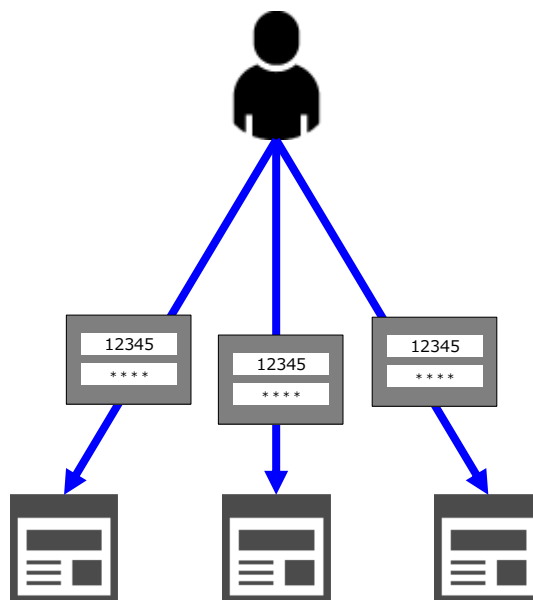
サービス連携

シングルサインオン (SSO)

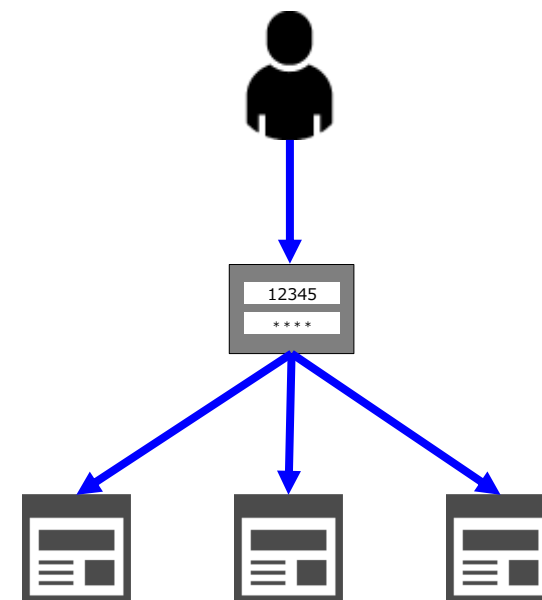
● シングルサインオン

- シングルサインオン (Single Sign On) とは、一つのログインで複数のサービスを利用できるようにする認証の思想です。
- ユーザーは、認証情報を管理する負担が軽減され、利便性が向上します。
- ログイン管理が一元化される一方で、システムとしては攻撃者に狙われる箇所が 1 箇所に集約されます。

散在した認証ポイント



Single Sign On



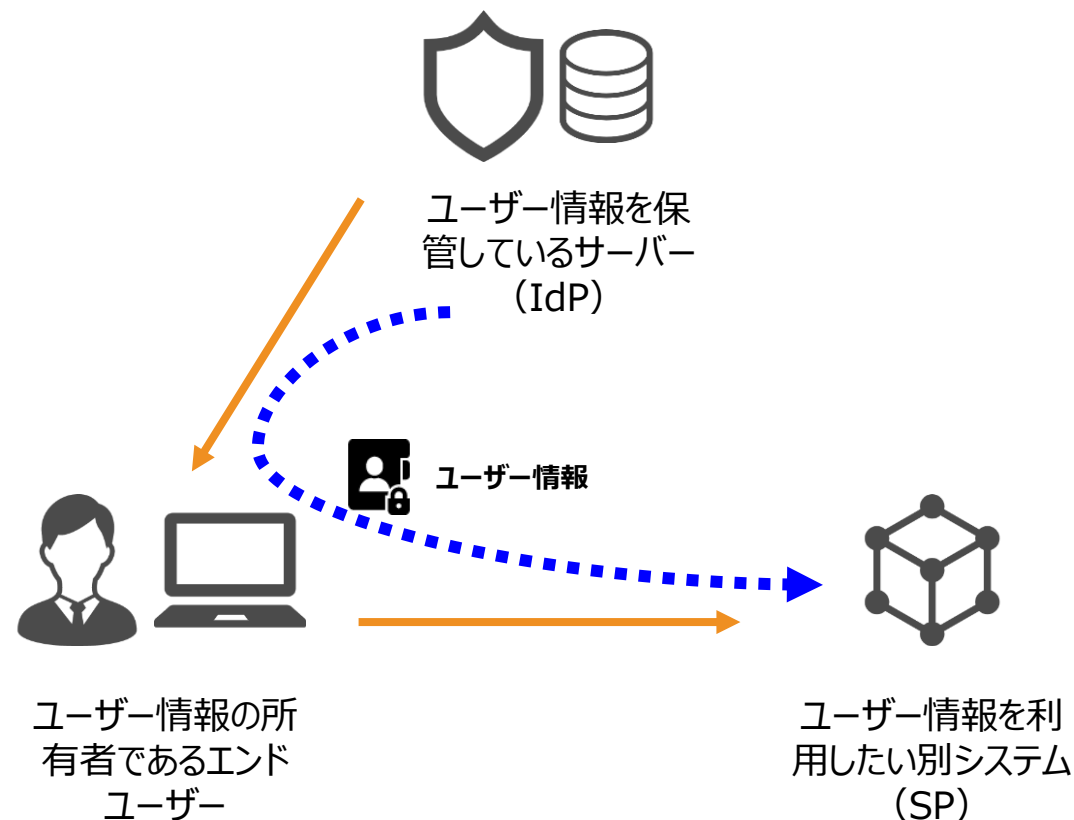
サービス連携

統合アイデンティティ管理（FIM）

●フェデレーション

SAML（ Security Assertion Markup Language ）

- XMLをベースにした異なるインターネットドメイン間でユーザー認証を行うための標準規格です。
- IdP（Identity Provider）はブラウザ経由でアカウント情報（アサーション）を連携し、SP（Service Provider）で署名検証します。
- SAMLでは、アカウント情報を最新化したいときにはユーザー認証を行う必要があります。



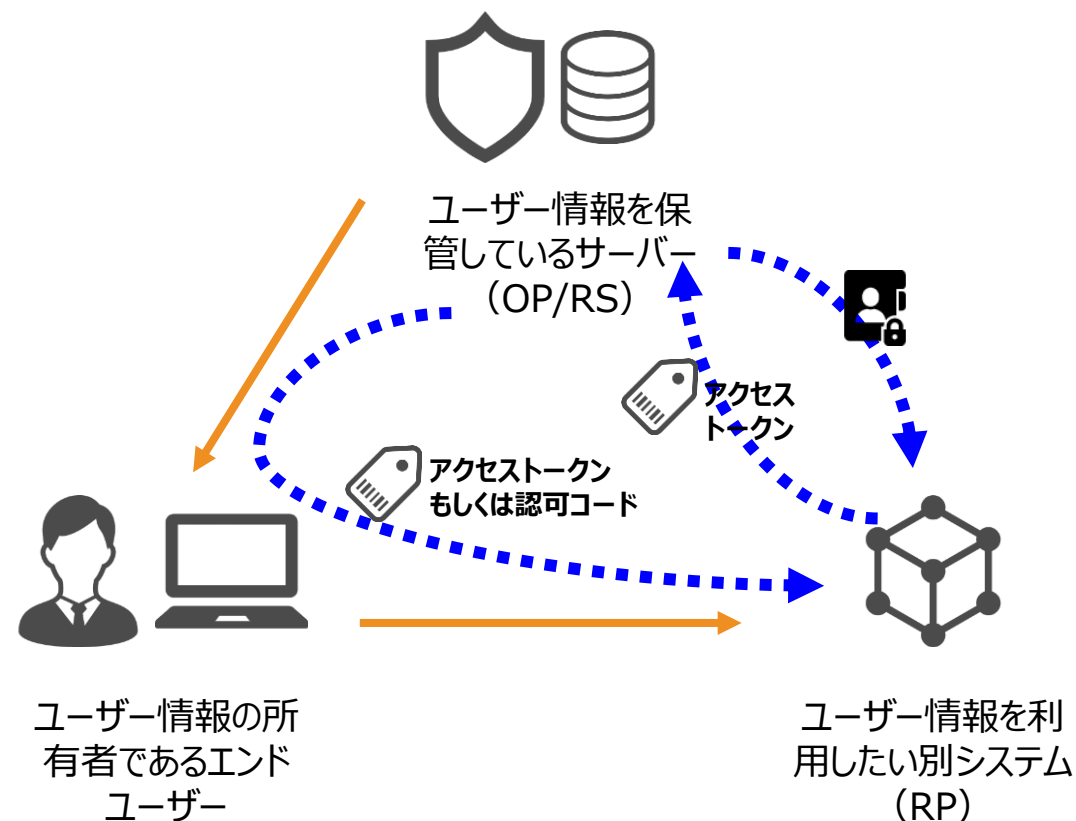
サービス連携

統合アイデンティティ管理（FIM）

● フェデレーション

OAuth

- OAuth（オーオース）とは、別システムで管理されているユーザー情報照会などのAPIを呼び出すためのフェデレーションの仕組みです。
- OAuthでは、ユーザー認証・同意許諾後にユーザー情報を渡すのではなく、アカウント情報を取得するためのアクセストークンを連携します。
- OAuthで連携したシステムは、アクセストークンを使えばシステム自身が判断して、好きなタイミングで最新のユーザー情報を紹介するAPIを呼び出すことができます。
- 当然、同意した内容に沿ったAPIのみが連携可能になります。



サービス連携

統合アイデンティティ管理（FIM）

●フェデレーション

OIDC（OpenID Connect）

- OIDC（OpenID Connect）とは、OAuthの後発としてアカウント情報の連携方法、トークン管理を整備した規格です。
- 基本的にはOAuthの規格をOIDCは包含していると考えてよいです。異なる点は、識別連携方法としてIDトークンと最新ユーザー情報取得方法としてのUserInfo APIを整備したものが、OIDCになります。

IDトークン

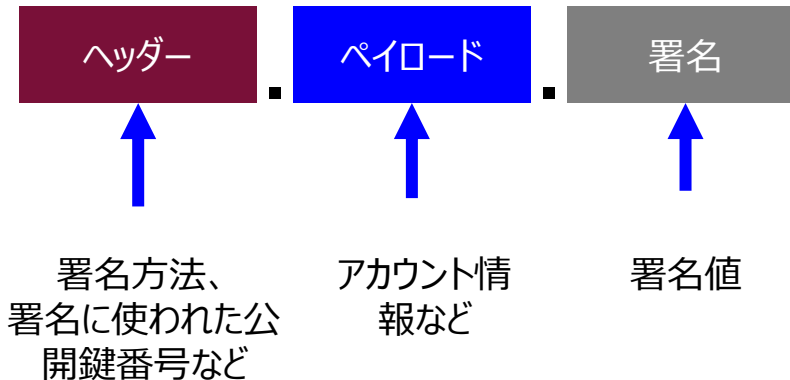
- ID トークンとは、認証されたユーザーの識別情報（名前やメールアドレスなど）に関するクレームが含むJSON ウェブトークン（JWT）です。つまり、基本的なアカウント情報だけをアクセストークンと一緒にタイミングで渡す仕組みです。
- JSON ウェブトークンは、いわゆる署名付きJSONデータであり、データ改ざんへの防御を持ったフォーマットです。

実際のIDトークン

eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiIxMjM0NTY3ODkwIiwibmFtZSI6IkpvaG4gRG9lIiwiaWF0IjoxNTE2MjM5MDIyfQ.SflKxwRJSMeKKF2QT4fwpMeJf36POk6yJV_adQssw5c



IDトークンの構成

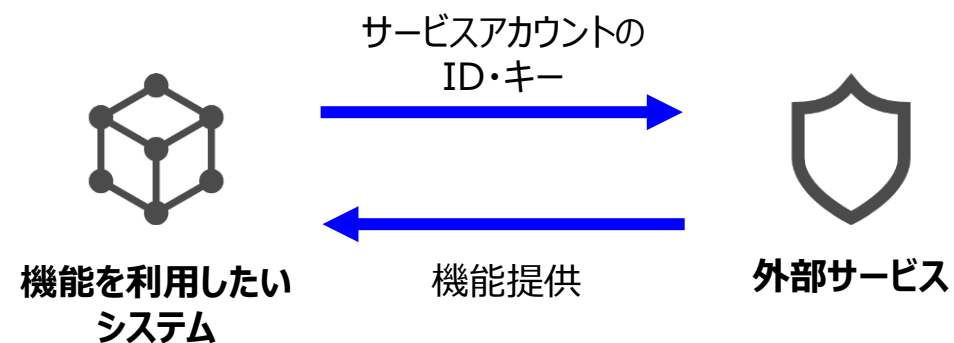


サービス連携

サービスアカウントの管理

● サービスアカウント

- サービスアカウントとは、特定のアプリケーションやシステムが他のシステムやリソースにアクセスするために使用される特別な種類のアカウントです。
- 一般ユーザーのアカウントとは異なり、特定のアプリケーションやサービスが自動的に作業を実行するために設計されています。





アクセス制御

アクセス制御

論理的コンポーネント

● アクセス制御の基本

- アクセス制御をモデル化するとき、アクセス主体とアクセス対象という関係性で整理します。

主体 (subject)

- 人間やコンピューターなど、データを操作する側を示す概念です。

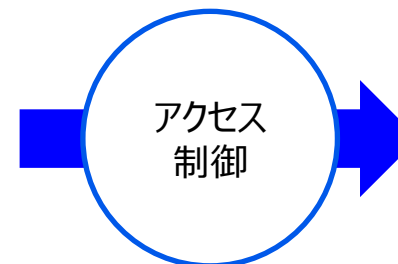
対象 (object)

- データそのものやドキュメントなど、データを操作される側を示す概念です。

Subject



Object



アクセス制御

論理的コンポーネント

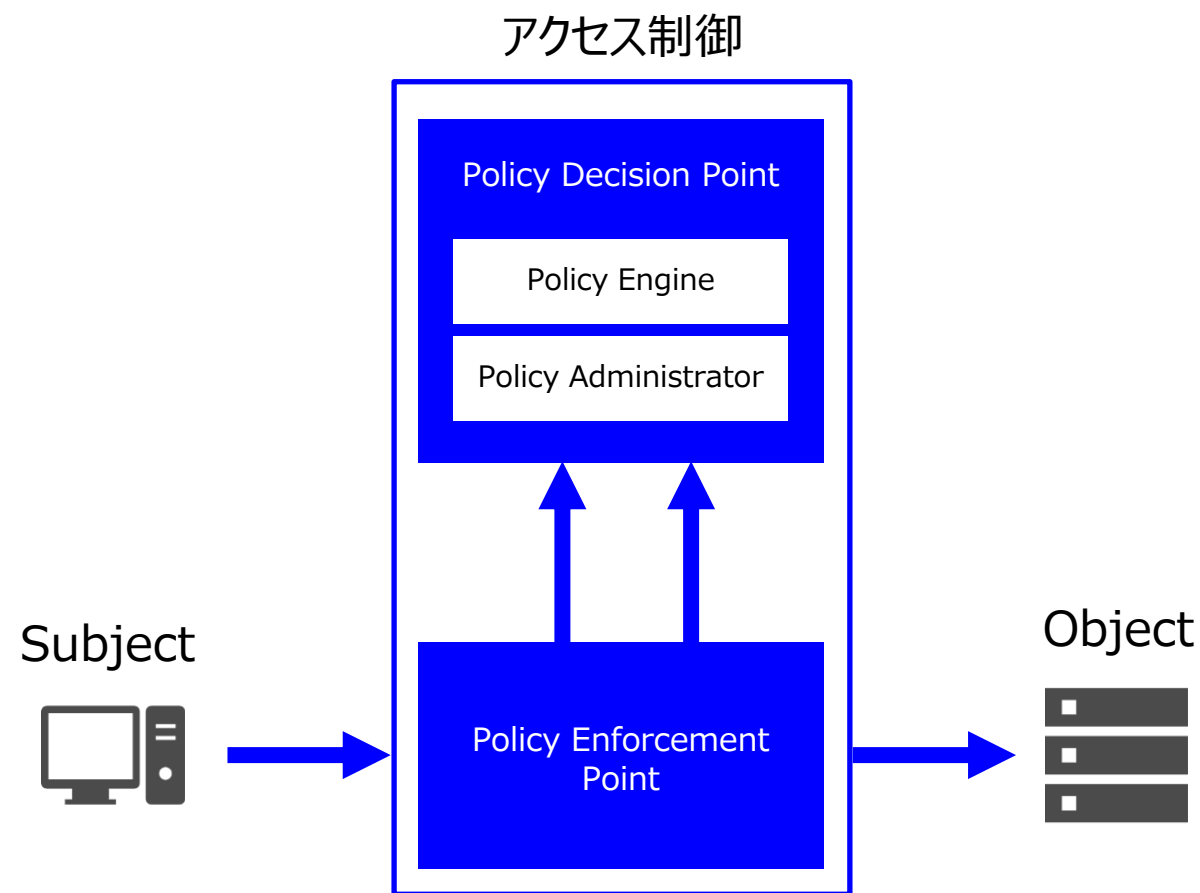
● アクセス制御の内部

Policy Decision Point

- 特定のリクエストに対してアクセスを許可するか拒否するかの「決定」を行う場所です。
- Policy Engineとは、アクセス制御の「意思決定」を行う中心的なコンポーネントです。
- Policy Administratorとは、アクセス制御の「実行」を担当するコンポーネントです。

Policy Enforcement Point

- 実際にアクセス制御を実施する場所です。Policy Decision Pointからの決定に基づき、リクエストされたリソースへのアクセスを許可または拒否します。



アクセス制御

アクセス制御

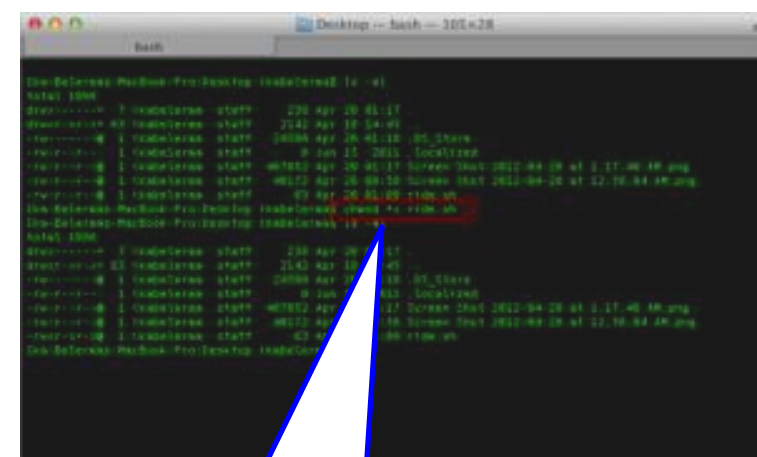
● アクセス制御の種類

任意アクセス制御（DAC、Discretionary Access Control）

- リソースの所有者がアクセス権限を管理する方式です。所有者は、他のユーザーに対してアクセス権限を自由に付与または制限できます。
- リソースの作成者や所有者がアクセス権限を持ち、他のユーザーに対してアクセス許可を設定できます。

強制アクセス制御（MAC、Mandatory Access Control）

- セキュリティポリシーに基づいて、アクセス権限が強制的に設定される方式です。セキュリティレベルに従い、システム管理者がリソースとユーザーにセキュリティラベルを付与し、アクセスを厳格に管理します。
- 各リソースにセキュリティラベルが割り当てられ、ユーザーも同様にセキュリティレベルを持ちます。リソースのセキュリティレベルとユーザーのクリアランスが一致しないとアクセスが許可されません。

A terminal window showing the output of the 'ls -l' command. The output lists several files and directories. The file 'memo' is highlighted with a red box, showing its permissions as '-rw-r--r--'. A blue arrow points from this box to a separate box below containing the permissions and file name.

-rw-r--r-- tom users memo

任意アクセス制御であるLinuxにおいて、memoファイルにtomユーザが読み取り権限と書き込み権限を設定

アクセス制御

アクセス制御

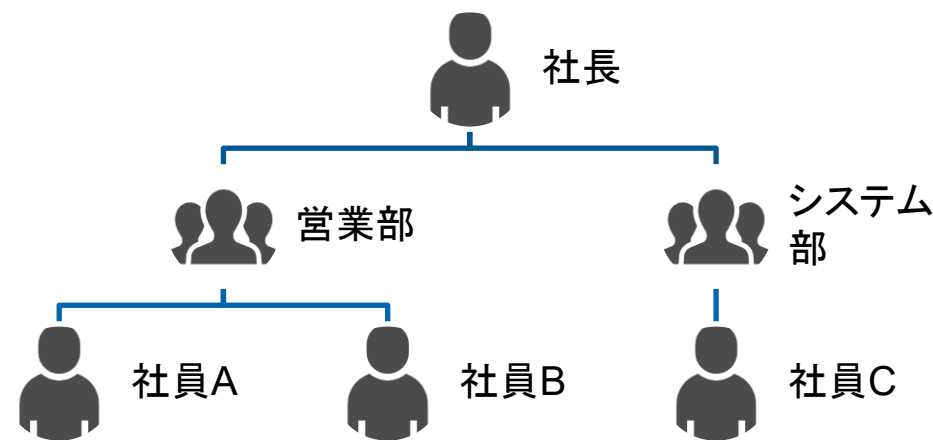
● アクセス制御の種類

属性ベースアクセス制御 (Attribute-Based Access Control)

- ・ ユーザー、リソース、環境などに関連する「属性」に基づいてアクセス制御を行う方式です。

ロールベースアクセス制御 (Role Based Access Control)

- ・ ロールベースアクセス制御は、ユーザーの「役割（ロール）」に基づいてアクセス権限を付与する方式です。組織やシステム内のユーザーの役割（たとえば、管理者、エンジニア、営業担当）に応じたアクセス権限を一括管理します。



ロールベースアクセス制御に基づき、会社での役割に基づいてアクセス権を付与する

アクセス制御

アクセス制御

● アクセス制御の種類

ルールベースアクセス制御 (Rule Based Access Control)

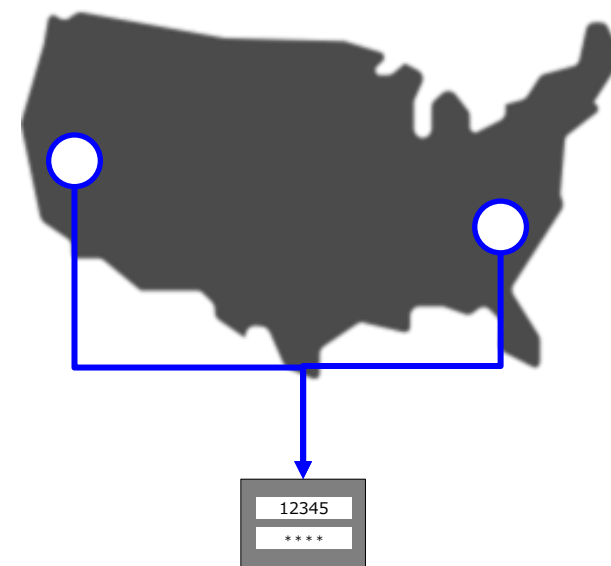
- ・ ルールベースアクセス制御は、特定のルールや条件に基づいてアクセス権限を設定する方式です。

リスクベースアクセス制御 (Risk-Based Access Control)

- ・ ユーザーや状況ごとの「リスクのレベル」に基づいてアクセスを動的に制御する方式です。
- ・ 従来の静的なアクセス制御方式とは異なり、セキュリティリスクを評価しながらリアルタイムでアクセスを許可または制限します。

時間ベースアクセス制御 (Time-Based Access Control)

- ・ 時間ベースアクセス制御は、アクセス権を特定の時間枠に基づいて制御する方式です。



離れた場所に支店があったとしても、同時にアクセスが来るのはおかしいため、再認証を要求する。

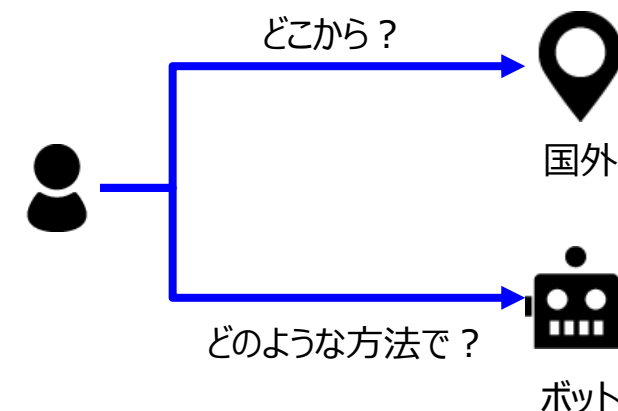
アクセス制御

アクセス制御

● アクセス制御の種類

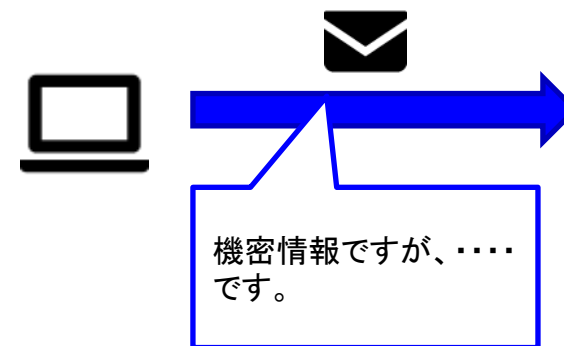
コンテキスト依存型アクセス制御（Context Dependent Access Control）

- アクセスの状況や文脈に応じて制御する方式です。
- 「コンテキスト」は、アクセス時の場所、使用デバイス、ネットワーク環境、ユーザーの行動履歴など、アクセス状況に影響する外部条件を指します。



コンテンツ依存型アクセス制御（Content Dependent Access Control）

- コンテンツ依存型アクセス制御は、アクセス要求の対象となるデータやリソースの「内容」に基づいてアクセスを制御する方式です。
- データの機密度や重要度によってアクセスの可否が決定されます。





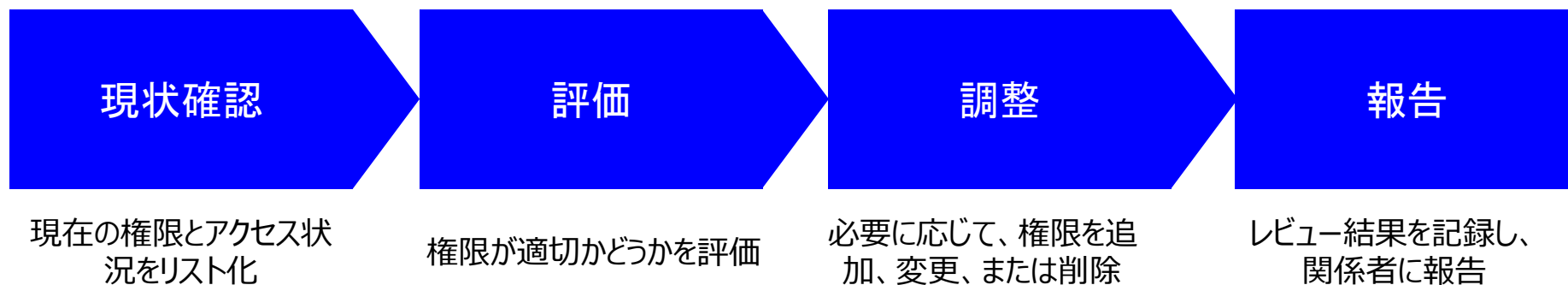
アカウントライフサイクル

アカウントライフサイクル

アクセスレビュー

● アクセスレビュー

- ・ 組織内のユーザーやシステムアカウントが適切な権限を持っているかを定期的に確認するプロセスです。
- ・ 不要なアクセス権や不適切な権限が付与されていないかをチェックし、セキュリティを維持します。
- ・ 組織においては役職の応じたアクセス権限を振り分けられただけに感じますが、そうではありません。急なタスク、社外の人に会社の一部のリソースを使ってもらったり、配置転換や退社、不正なアクセスの増加など、アカウントのリスクと権限は日々変化します。



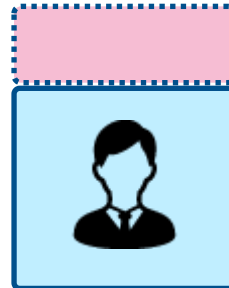
アカウントライフサイクル

アクセスレビュー

●最小権限の原則（ Principle of Least Privilege ）

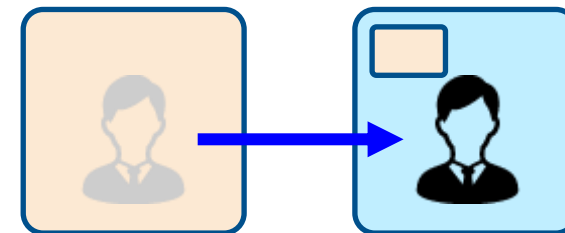
- ユーザーやシステムプロセスに対して、業務遂行に必要な最小限の権限のみを付与するというセキュリティの概念です。
- この原則に従うことで、システム全体のセキュリティが向上し、不正アクセスや情報漏洩のリスクが軽減されます。

権限超過



新しい職に就いたとき、管理者が間違えて大きなアクセス権限を付与していた。

権限クリープ



他のチームに配属になって、職権が変わったのに前の権限が残っていた。

アカウントライフサイクル

プロビジョニング

● プロビジョニングライフサイクル

アカウントの登録（プロビジョニング／オンボーディング）

- 適当な入社プロセスを行い従業員として登録が行われます。外部の人間を本人であることを確認するためには、パスポートや運転免許証などの公的証明書が利用されます。
- 証明書の確認後、人事（HR）は従業員の登録作業を行います。アカウントの登録によって、新しい従業員に対し識別情報である従業員番号もしくはメールアドレスと認証情報であるパスワードを割り当てられ、登録アカウントで組織のリソースにアクセスすることを許可します。
- パスワードだけではなく生体認証といったよりセキュアな認証システムを導入している場合、従業員の指紋登録といったプロセスも発生します。

アカウントの削除（デプロビジョニング／オフボーディング）

- 従業員が会社を離れるとき、速やかにアカウントを無効してください。
- 完全にデータ削除すると退社や退社後において内部犯行的な問題が発生した場合であっても復元処理が困難になるため、管理者がパスワード変更もしくはアカウント停止をし、対象の従業員がアカウントを利用できないようにすることが一般的です。

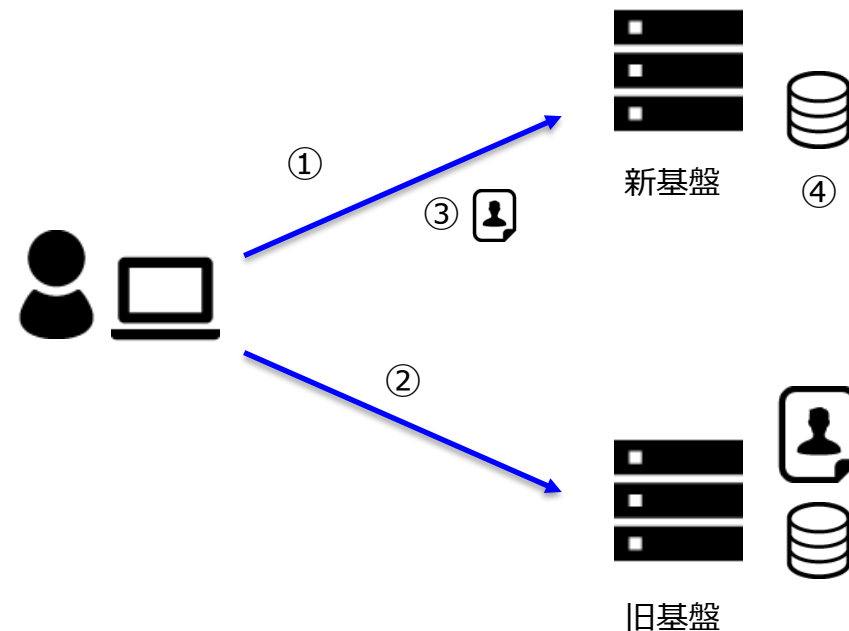
アカウントライフサイクル

プロビジョニング

● フェデレーションを利用したプロビジョニング

ジャストインタイムプロビジョニング

- アカウント登録する際に、SAML（ Security Assertion Markup Language ） プロトコルを使用して、既に登録されている他のサイトからアカウント情報を取得することです。
- アカウント管理者の負担を大幅に減らすことのできるメリットがあります。



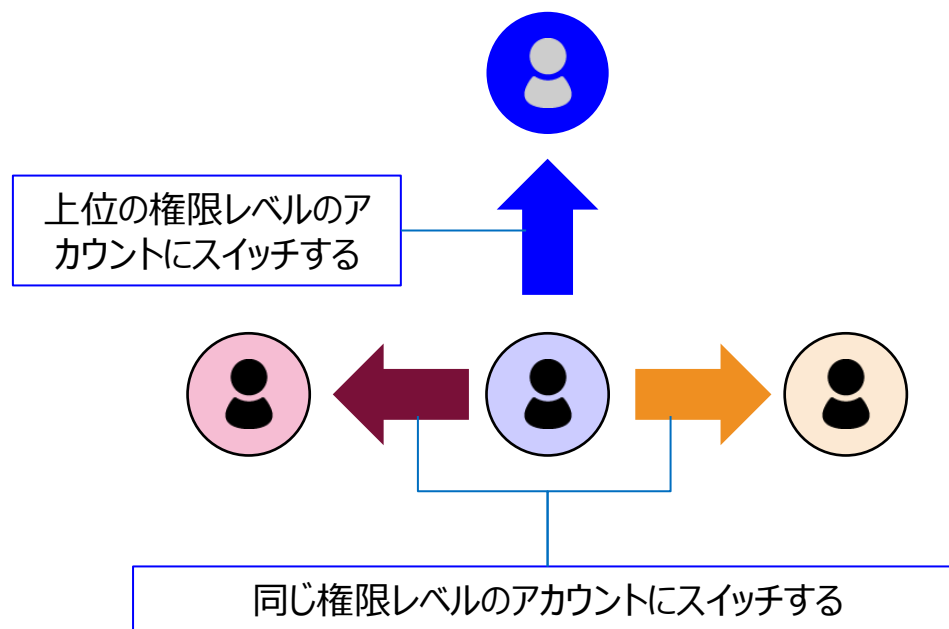
- ① 新基盤でサービス利用（まだ新基盤にアカウントがない）
- ② 新基盤から旧基盤にSAMLリクエスト
- ③ 旧基盤から新基盤のSAMLレスポンス
- ④ 受け取ったアカウント情報を新基盤に登録

アカウントライフサイクル

特権の昇格

●特権の昇格（Privilege Escalation）

- ユーザーやアカウントが、本来持っていないはずの権限を取得し、不正にシステムやデータにアクセスする行為を指します。
- ユーザーがより高い権限を持つアカウントを取得、もしくは同じ権限レベルの他のアカウントに不正アクセスします。





認証システムの実装

認証システムの実装

統合ID基盤

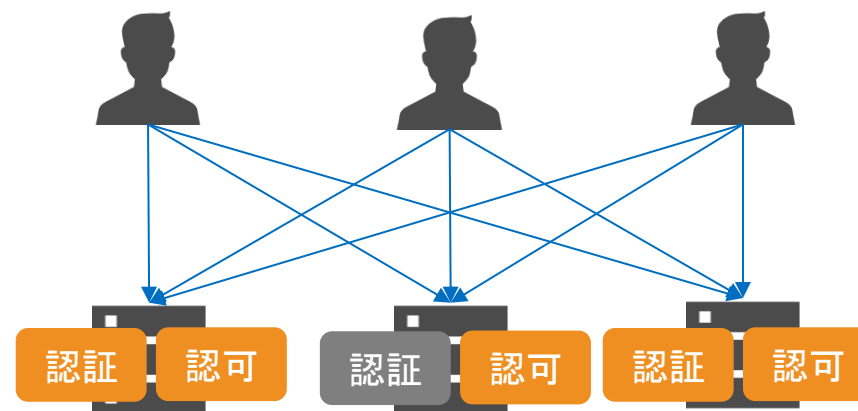
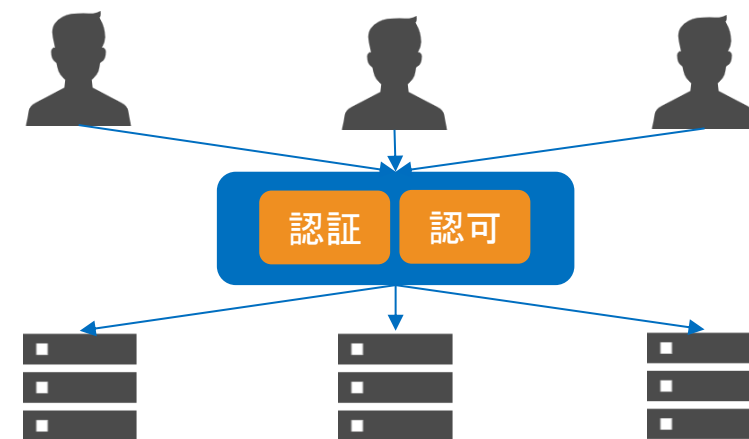
● 認証基盤

中央アクセス制御

- ・ アクセス制御を行う機構が論理的に集中している体系です。
- ・ 多岐に渡るシステムに対して認証と認可を一か所に統括することを目的にします。
- ・ リバースプロキシ方式である認証基盤では、このコンセプトに則っています。

分散アクセス制御

- ・ 認証・認可を一か所に集約するのではなく、個々のシステムで行うことです。
- ・ 拠点では、認証機能を別システムの機能に従属している場合があります。
- ・ エージェント方式である認証基盤では、このコンセプトに則っています。

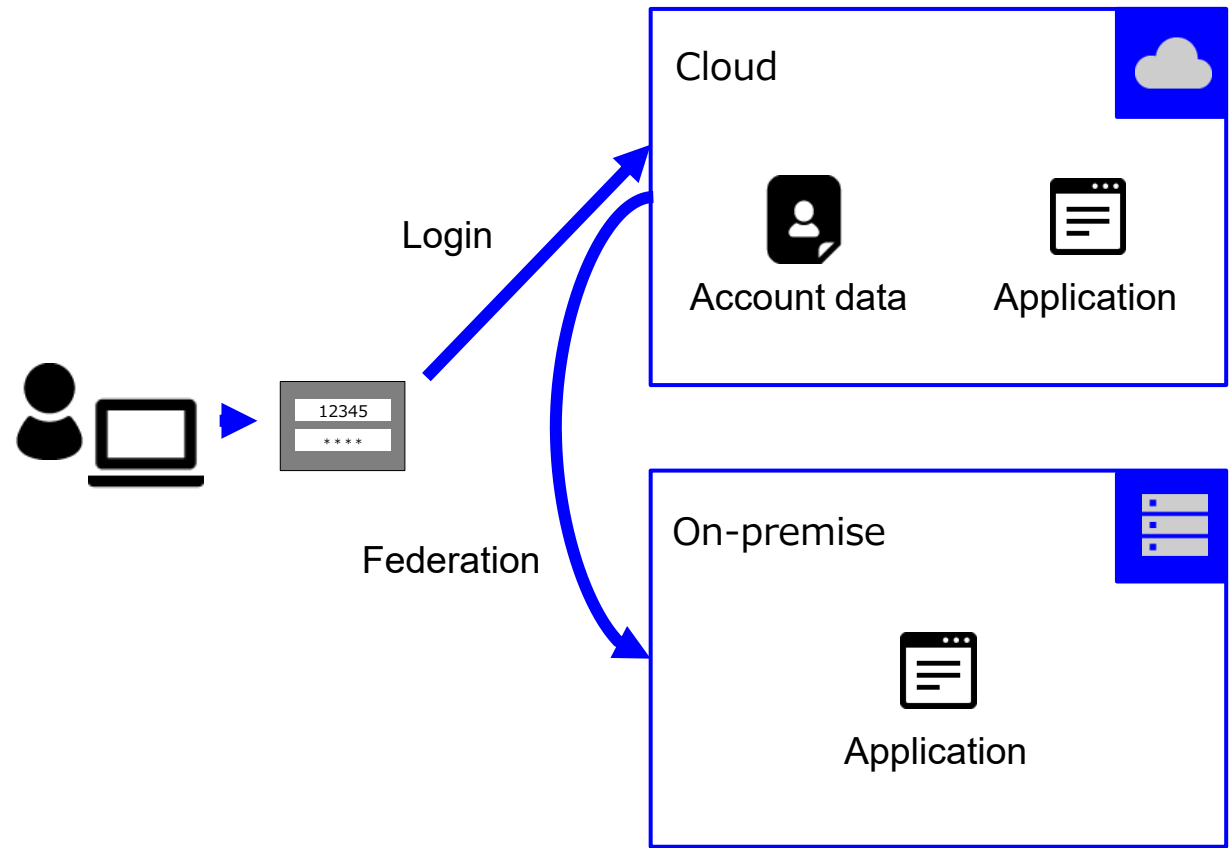


認証システムの実装

統合ID基盤

●ハイブリッド環境

- ・ オンプレミス（自社運営）のインフラとクラウドサービスを組み合わせたIT環境を指します。
- ・ ハイブリッド環境では、アプリケーションやアカウントデータが散在する可能性が高くなります。
- ・ アカウントが散在すると、管理が極めて困難になります。
- ・ フェデレーションを利用して、アカウントデータや認証ポイントが散在しないようにしましょう。

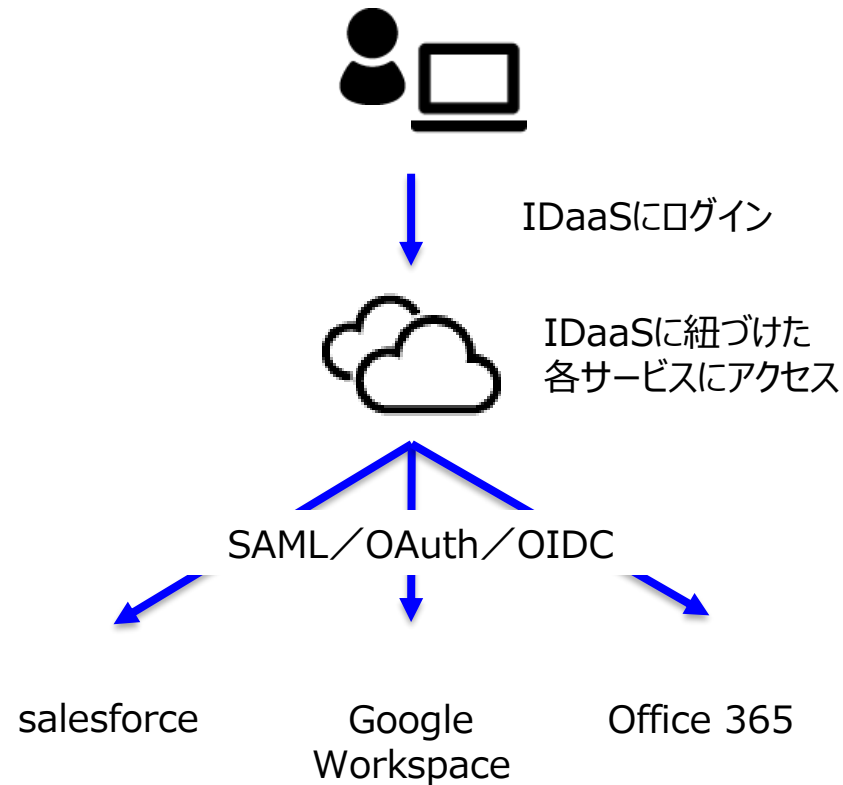


認証システムの実装

統合ID基盤

● IDaaS (Identity as a Service)

- サービスで利用するアカウント情報の管理やログインを行うためのクラウドサービスです。
- 安全にユーザー情報を連携してサービス展開できるゼロトラストネットワークを実現する一つのアプローチがIDaaSです。



OktaがAuth0を買収

2021年5月3日、米OktaはIDaaSを手掛ける米Auth0の買収を完了したと発表した。IDaaSのリーダーとして一層の業界の加速が狙いだ。しかし、同じIDaaSとして競合でもあるために、時間をかけて統合してより強いシナジーを得ていくと、米Okta COO兼共同創業者のフレデリック・ケレスト氏は説明している。

<https://www.okta.com/jp/blog/2021/04/its-official-okta-joins-forces-with-auth0/>

認証システムの実装

統合ID基盤

●ネットワーク接続の認証プロトコル

- RADIUS、Diameter、TACACSは、ネットワークの認証・認可・アカウントिंग（AAA）を管理するプロトコルです。

RADIUS (Remote Authentication Dial In User Service)

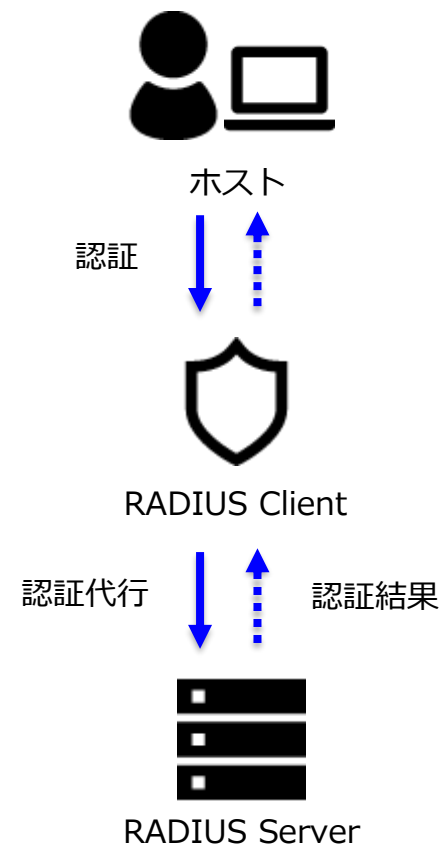
- 古くから使われるプロトコルで、リモートアクセスやWi-Fi認証に強みです。UDPを使用し、暗号化は限定的です。

Diameter

- RADIUSの後継として開発され、TCPを使用し暗号化が強化。主にモバイルネットワークで利用します。

TACACS (Terminal Access Controller Access-Control System)

- TACACS+が一般的で、認証・認可・アカウントिंगを完全分離し、パケット全体を暗号化します。主にネットワーク機器の管理者アクセスに用いられます。



認証システムの実装

Active Directory / Entra ID

● Active Directory / Microsoft Entra ID

Active Directory

- Microsoftが開発したディレクトリサービスで、Windowsドメインネットワークを管理するためのシステムです。
- ネットワーク上のユーザーアカウント、コンピュータ、プリンタ、およびその他のデバイスの情報を一元的に管理し、組織全体のアクセス制御やセキュリティポリシーを設定することができます。

Microsoft Entra ID

- Microsoftが提供するユーザー認証とアクセス管理のためのクラウドサービスです。

特徴	Active Directory (AD)	Microsoft Entra ID (旧 Azure AD)
提供形態	オンプレ	クラウド
対象ユーザー	社内ネットワークのユーザー	クラウドアプリやリモートアクセスが必要なユーザー
プロトコル	Kerberos、LDAP	OAuth 2.0、OpenID Connect、SAMLなど
認証方式	ドメイン参加デバイスでの認証	クラウドアプリ向けのSSOやMFA
用途	主に社内のリソースアクセス制御	クラウドアプリ、モバイルデバイス、リモートアクセス向け

認証システムの実装

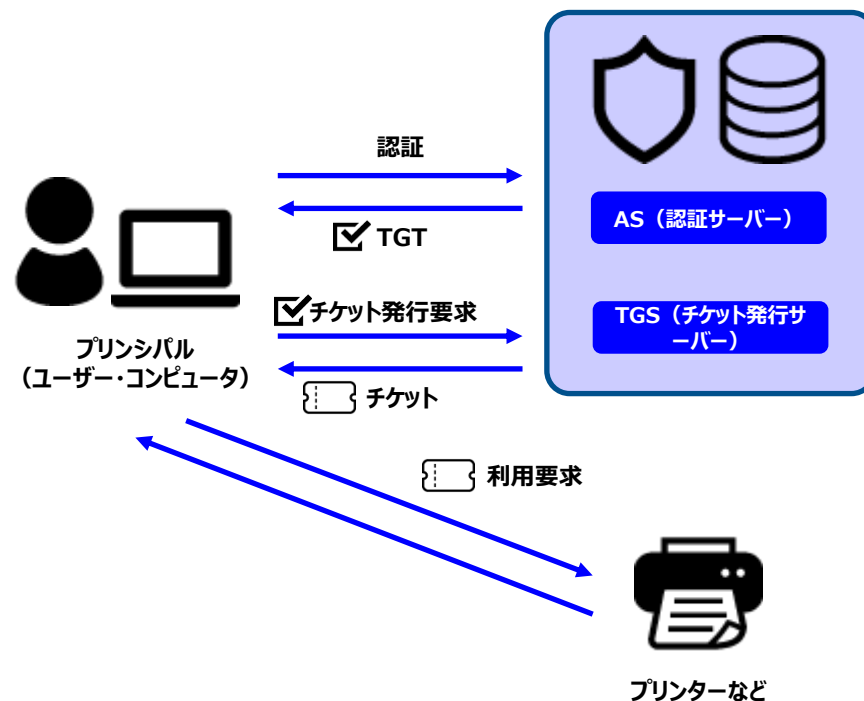
Active Directory / Entra ID

● Active Directory

ケロベロス (Kerberos) 認証

- ユーザー認証した後は、事前設定済みのサービスに、認証結果を連携することで、ユーザは一回のログインで様々なサービスを利用できるようになります。

機構	内容
KDC (Key Distribution Center)	ユーザーを認証し、サービスを利用に必要なチケットを発行するための場所です。役割として以下の2つの機能を提供します。
AS (Authentication Server)	本人認証するサーバーです。ASはユーザを認証するサーバーです。本人確認できるとチケットを発行するためのチケットを発行します。
TGS (Ticket Granting Server)	チケットを発行するサーバーです。
プリンシパル (principal)	サービスを利用するユーザーやコンピューターです。
レルム (realm)	チケットが使える領域です。



ケロベロス認証のチケット配布

認証システムの実装

所持認証

●スマートカード

- 内蔵されたマイクロチップを使って情報を保存し、読み取り装置と通信できるカード型デバイスです。
- 一般的なプラスチックカードに集積回路（ICチップ）を組み込むことで、従来の磁気カードに比べてセキュリティ機能やデータ容量が格段に向上しています。
- 磁気ストライプカードは、コンピューター回路を内包しおらず、リーダーをスワイプすることで読み取ります。この手のカードは複製は非常に簡単です。



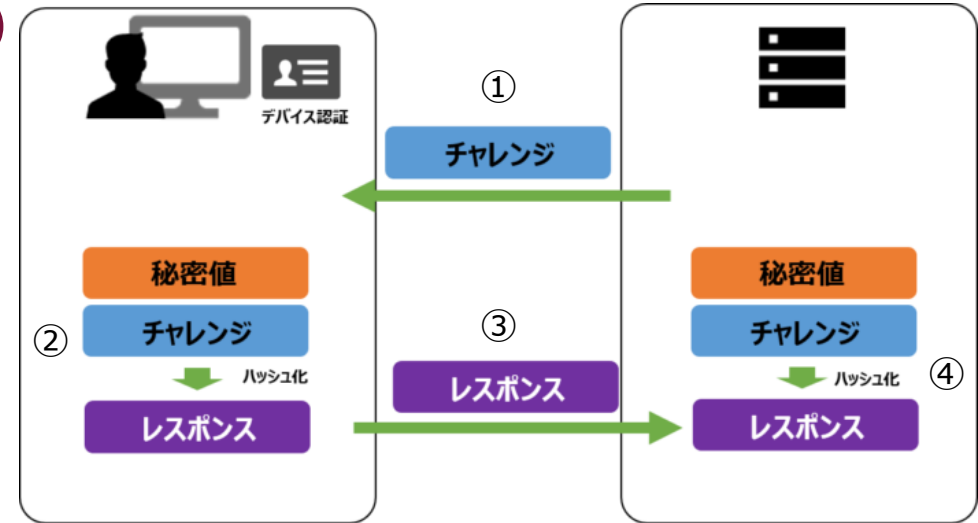
認証システムの実装

所持認証

●非同期動的トークン（asynchronous dynamic token）

チャレンジレスポンス認証

- チャレンジレスポンス認証とは、パスワードといった機密情報を通信経路に流すことなく認証を行う方式です。
- 適切なハッシュ化を行うと、一意の値が取得できます。この性質を利用し、サーバーからランダムな文字列であるチャレンジに対してパスワードのハッシュ値をレスポンスとして返却します。秘密値（パスワード、秘密鍵など）は通信経路に流れません。その上、チャレンジごとにレスポンスの値が変わるためワンタイムの性質も持ち合わせます。



チャレンジレスポンス認証による非同期動的トークン検証

- ①チャレンジ（ランダム文字列）を連携
- ②事前に連携された秘密鍵（もしくはパスワード）とチャレンジをハッシュ化
- ③レスポンス電文を生成
- ④自環境で算出したハッシュ値とクライアントから受け取ったレスポンスを照合

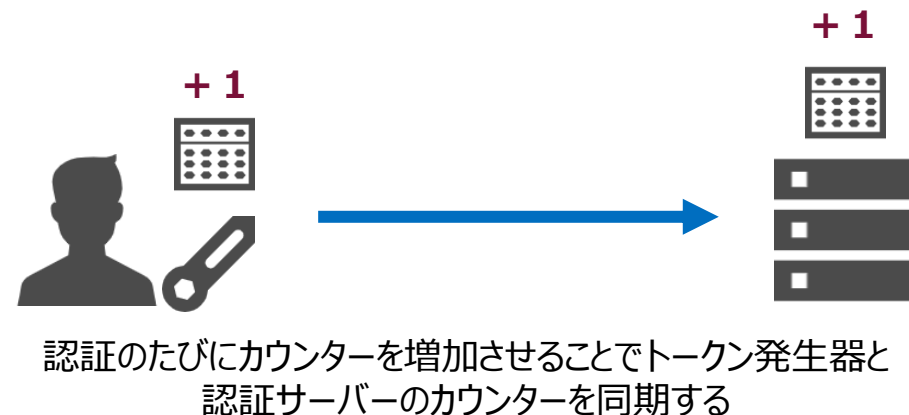
認証システムの実装

所持認証

●同期動的トークン (synchronous dynamic token)

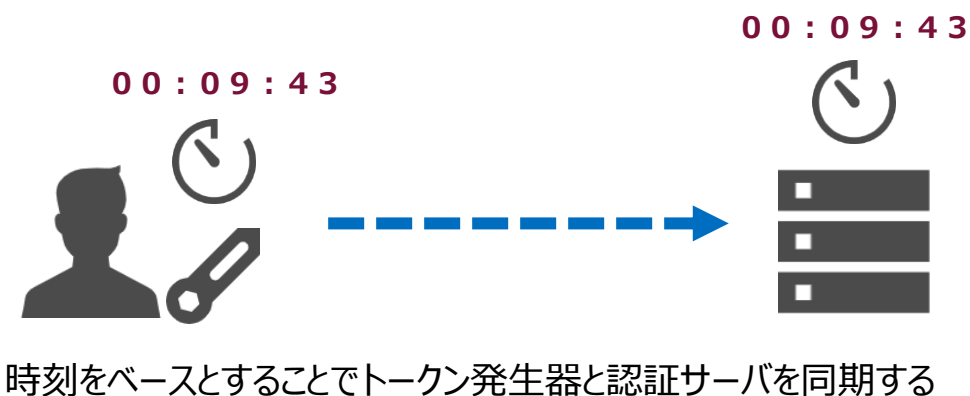
カウンターベース同期動的トークン

- 試行回数に同期しながらトークンを発行します。所持する認証デバイスと認証を行うサーバ間で試行回数をそれぞれ数えて置き、試行回数が同じであれば、同じトークンを発行する事ができ認証完了とする方式です。



時間ベース同期動的トークン

- 時刻に同期しながらトークンを発行します。登録したで認証デバイスから発行され、かつ同時刻に発行されたトークンであれば認証できるようになっています。時刻からトークンを発行するため、一定時間でトークンは変更されます。

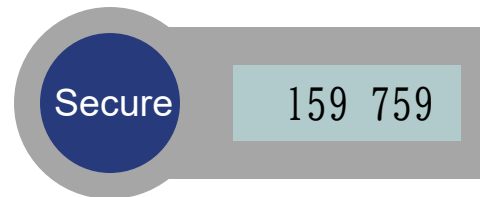


認証システムの実装

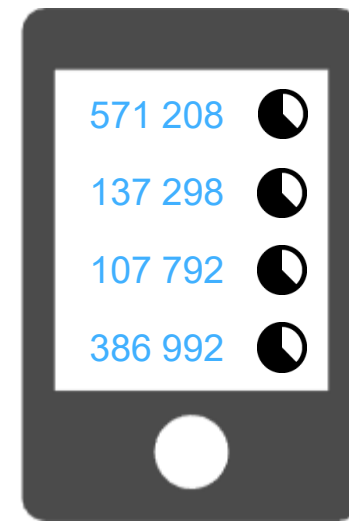
所持認証

● トークン発生器

- トークン認証を行う際、トークン発生器として使うデバイスを登録する必要があります。
- ハードウェアベースとは、RSA SecureIDなどの専用の認証機器を利用して行うものです。
- ソフトウェアベースとは、Google Authenticationなどのアプリケーションをインストールすることで、そのデバイス（多くの場合がスマートフォン）がトークン発生器として動作可能なものです。



ハードウェアベースのイメージ



ソフトウェアベースのイメージ

認証システムの実装

パスワードレス認証

●パスワード認証

静的パスワード

- 静的パスワードとは、一般的な言うパスワードであり、自身に変更するまでは認証に同じパスワードを使いまわせるものです。
- あなたが、あるサイトにログインするとき以前と同じパスワードで認証することができます。

パスフレーズ

- パスフレーズとは、文字列というよりも文章をパスワードを扱うものです。秘密の質問がこのケースに当てはまります。
- 残念なことに文章というのは規則性があり、推測しやすくなる傾向がある。パスワード文字が長い代わりにランダム性を失っているとも言い換えられます。

秘密の質問は終わり

2015年5月、Google社はGoogleアカウントの復旧に使用された数億件の秘密の質問について、その答えをクラッカーがどのくらい正解できるのかを調査しました。（「Secrets, Lies, and Account Recovery: Lessons from the Use of Personal Knowledge Questions at Google」、<https://research.google/pubs/pub43783/>）結論として、秘密の質問はそれ単体ではアカウント復旧の仕組みとして使用するには安全性はないと、されました。

認証システムの実装

パスワードレス認証

●パスワード認証

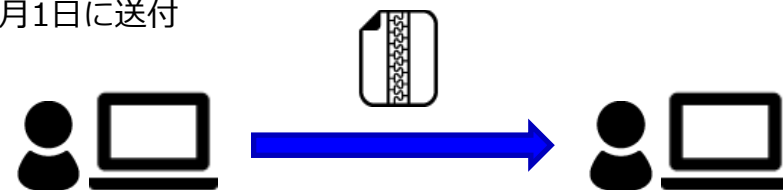
ワンタイムパスワード

- ワンタイムパスワードは、認証ごとにパスワードが変更するものです。
- 一度利用されたパスワードは2回目以降も使われる確証はなく、静的パスワード認証よりもセキュアであると言えます。

動的パスワード

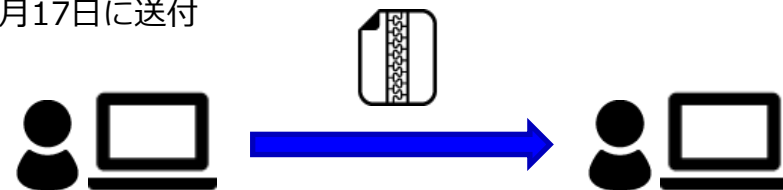
- 動的パスワードは、定期的に変更になるパスワードです。主に、時間経過によりパスワードが変更します。
- ワンタイムパスワードには、パスワード発行されてから認証を行うまでの間、ワンタイムパスワードは変更できませんが、動的パスワードの場合は定期で自動的に変更されます。

9月1日に送付



ファイル暗号パスワード :
password0901

9月17日に送付



ファイル暗号パスワード :
password0917

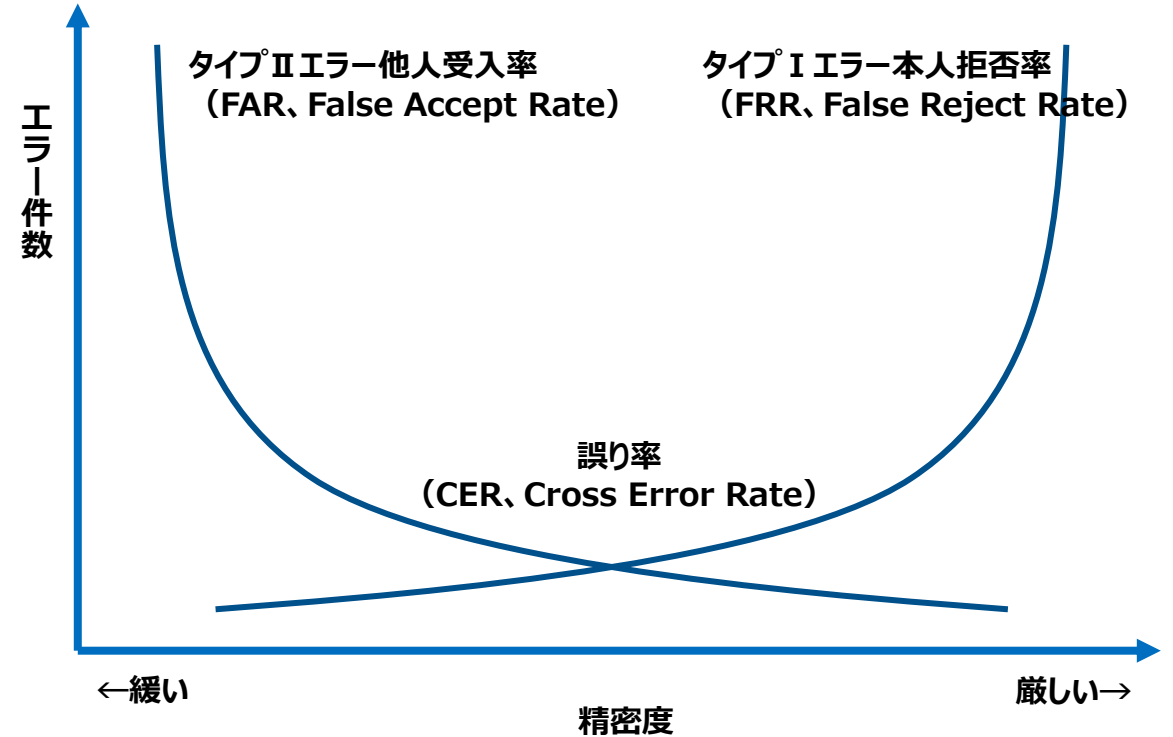
認証システムの実装

パスワードレス認証

● 生体認証

生体認証の精度

- エラー件数と精密度から最も誤り率の低い粒度を探します。タイプ I エラー本人拒否率とは、ある本人の生体情報に対して本人を拒否してしまったか比率です。タイプ II エラー他人受入率とは、ある本人の生体情報に対して本人以外の他人を許可してしまった比率です。
- ここでの精密度では、「どれだけ厳格に一致を求めるか」を示しています。



誤り率 (CER, Cross Error Rate)
= タイプ I エラー本人拒否率 (FRR, False Reject Rate)
+ タイプ II エラー他人受入率 (FAR, False Accept Rate)

認証システムの実装

パスワードレス認証

● 生体認証

Zephyrチャート

- ゼフィアー（Zephyr）チャートとは、各身体部位ごとの精度比較グラフです。
- 指紋、声帯、虹彩などの比較を行うことができ、本人拒否率・他人受入率・コスト・労力によって評価される。

「ミッション：インポッシブル」の生体認証の突破法

「ミッション：インポッシブル」の第1作では、指紋認証を突破するために指紋の成りすましではなく、認証サーバーの認証情報を書き換えることで侵入に成功します。第2作では、声紋認証ではボイスレコーダーを使って容易に侵入する様子が描かれています。確かに、Zephyrチャートを見ても指紋認証の侵入は難しく、声紋認証の侵入しやすさはとても高く、IMF（作中の秘密組織）は同じグラフを見ていたかもしれませんね。

認証システムの実装

パスワードレス認証

● FIDO2

- FIDO (Fast IDentity Online) Allianceとは、パスワードを使わずに認証を行うための技術の開発と標準化を行う業界団体です。
- FIDO2は、FIDO Allianceが推し進める認証技術の1つです。
- FIDO2およびWeb認証により、WindowsやAndroid端末上で主要ブラウザが対応しており、パソコンやスマホがそのままFIDO2対応機器となります。これにより、指紋認証や顔認証、虹彩認証といったパスワードを使わない認証処理をオンライン上で実施できるようになります。

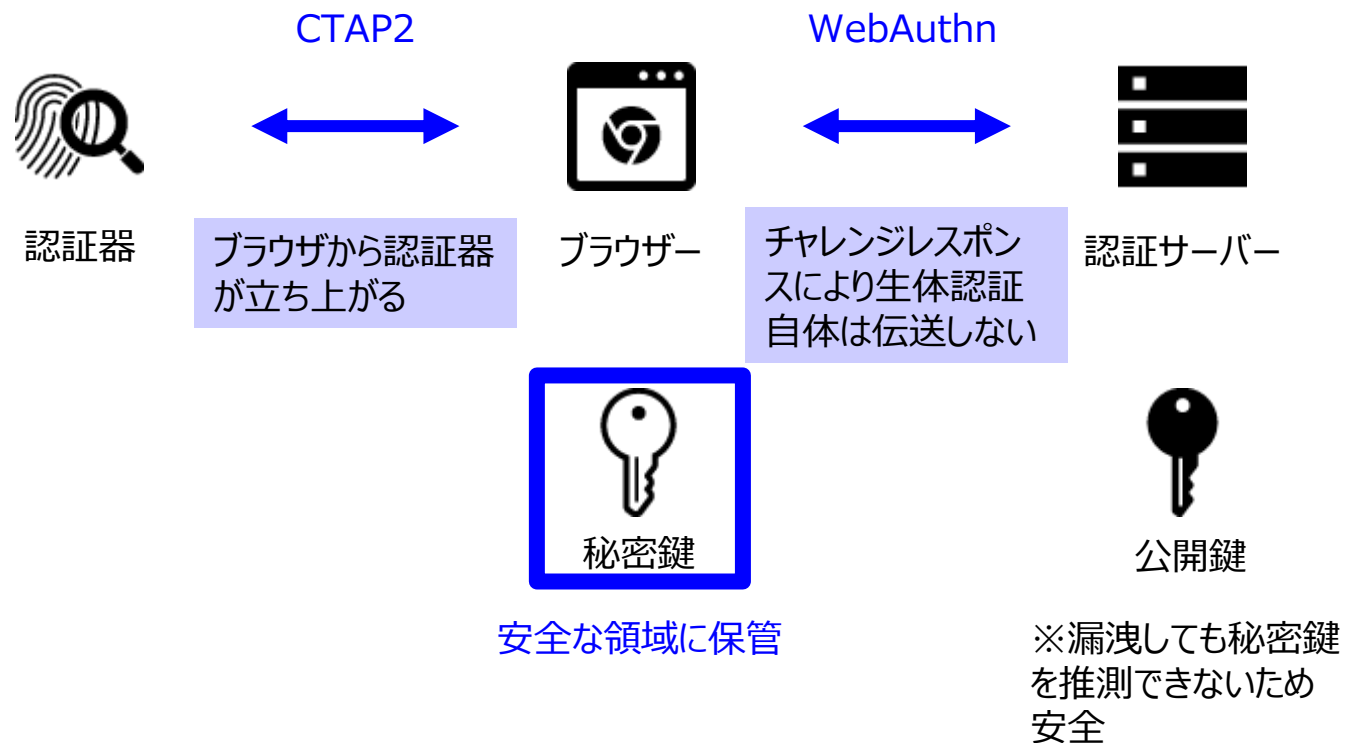
認証システムの実装

パスワードレス認証

● FIDO2

FIDOコンポーネント

- CTAP2とは、FIDO2認証を成立させるためのオペレーティングシステム・ブラウザ側の仕様です。
- W3C WebAuthn（Web認証）とは、FIDO2認証を成立させるためのクライアントとサーバー間の通信の仕様です。
- 生体認証情報自体をサーバーに保管するわけではありません。認証は端末に任せて、その認証結果を公開鍵を利用した認証を実施しています。そのため、サーバー側の生体認証に紐づく鍵情報を盗んでも、他のシステムで悪用できない特性があります。



認証システムの実装

不正ログイン

● 認証の突破

ブルートフォース攻撃

- ブルートフォースとは、パスワードを無作為に当てようとする不正ログインです。
- 一般に試行する文字列は推論や統計的データによって得られたものではなく、ランダムな文字列を生成し、ログイン試行を繰り返します。つまり、パスワードのランダム性の脆弱性をつく攻撃です。

辞書攻撃

- 辞書攻撃とは、単語をパスワードにしているユーザーを狙う不正ログインです。
- 攻撃者は、単語や文章など覚えやすいものをパスワードにしていることを想定し、不正ログインを試みます。

パスワード認証の終焉は来るのか

Microsoft会長のビル・ゲイツは、「従来のパスワード認証システムは、重要な情報を保護するという課題に対応できないことから、今後廃れていくだろう」と予言した。

そして続けて、「生体認証やスマートカード技術がこれに取って代わるようになる」と述べました。

Microsoftでは社内でもパスワード認証を廃止する運動を行っていることが度々報道されています。

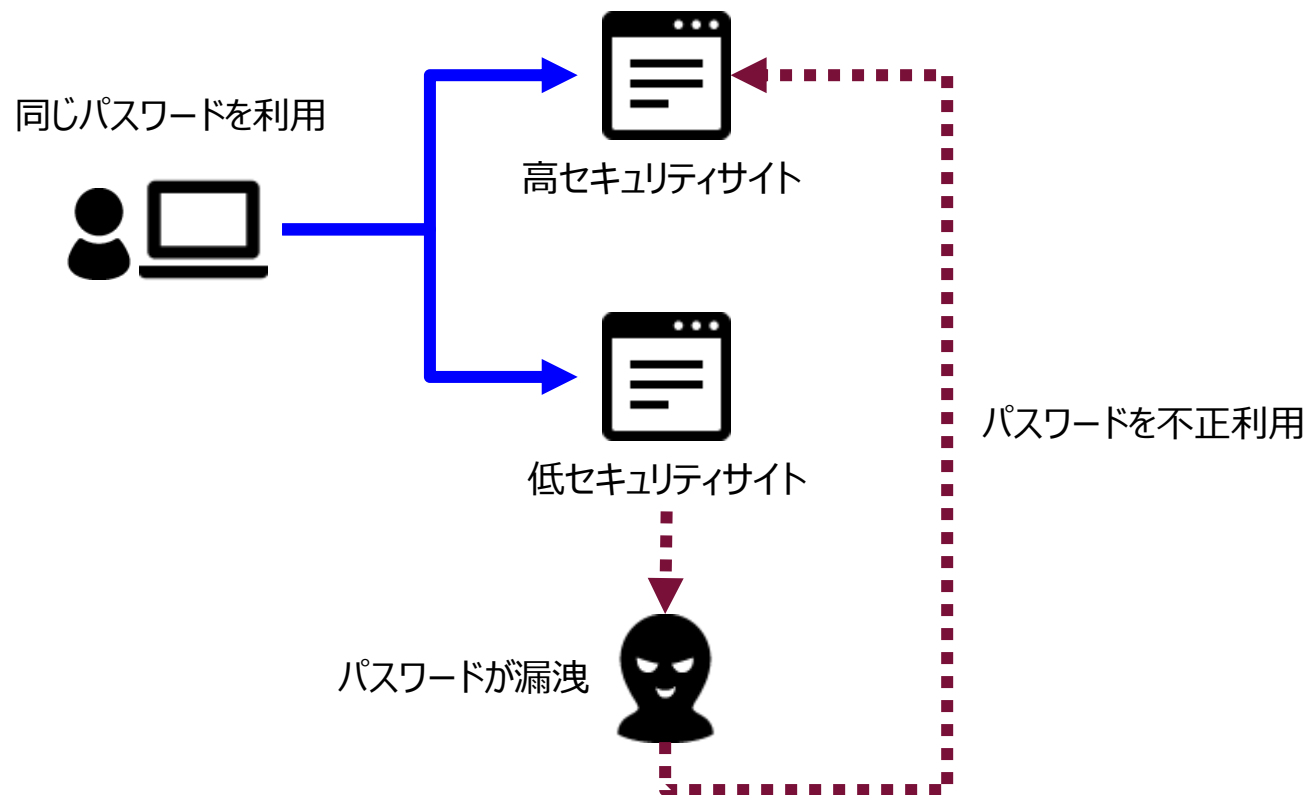
認証システムの実装

不正ログイン

● 認証の突破

パスワードリスト攻撃

- ・ パスワードリスト攻撃とは、ブラックマーケットなどから取得したログインIDとパスワードで、様々なサイトのログインを試行する攻撃です。
- ・ パスワードは複雑にすると非常に覚えにくいいため、色々なサイトで同じパスワードを使い回しがちです。そのため、脆弱性のある別のサイトから取得したログインIDとパスワードを攻撃対象のサイトで試すと成功する可能性があります。



認証システムの実装

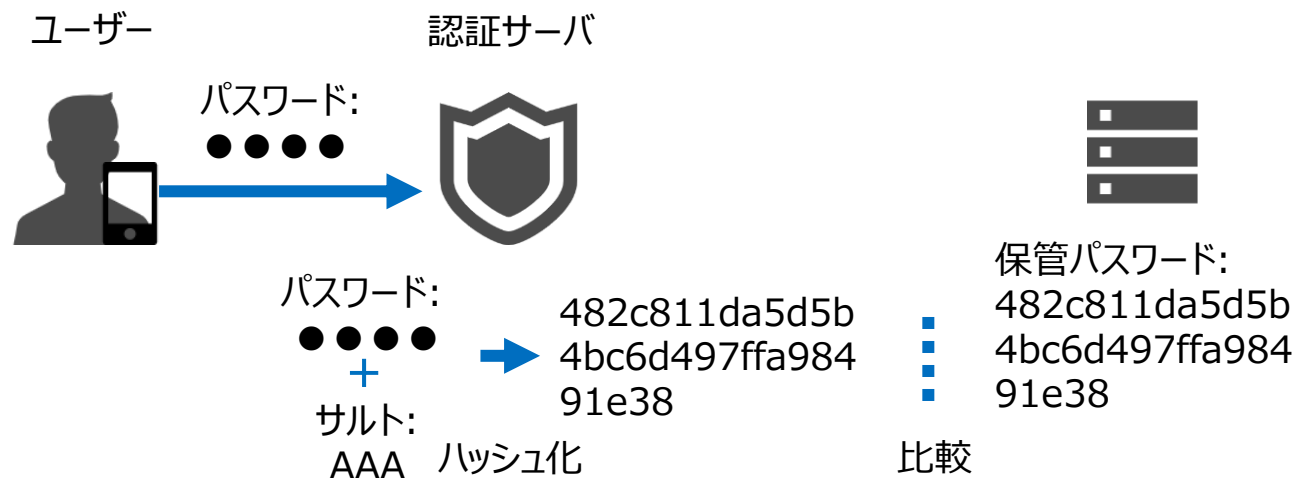
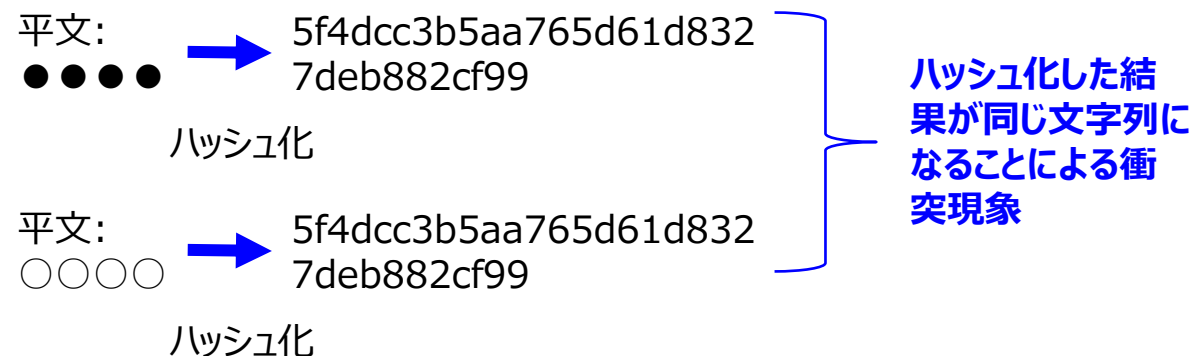
不正ログイン

●パスワードの推測

- パスワードは平文では保管されていません。一方方向暗号化（ハッシュ化）しています。
- ログインフォームで入力したパスワードは、認証サーバでハッシュ化し、ハッシュ化済みパスワードと比較されます。
- 暗号化は他の文字列に変える行為です。別の文字列なのに暗号された結果は同じになるケースもあります。この暗号化の現象を衝突といいます。

誕生日攻撃

- 少なくとも一つ重なっている確率が高いことを暗号化の衝突を利用して、不正ログインを効率的に行うことです。



認証システムの実装

不正ログイン

● パスワードの推測 レインボーテーブル

- レインボーテーブルとは、暗号化の衝突リストを利用して、不正ログインを効率的に行うことです。平文と暗号文のペアを事前に計算しておくことで逆引きします。
- ランダム文字で形成されるサルトを挿入後、暗号化する事で対応できます。



保管パスワード:
5f4dcc3b5aa765d6
1d8327deb882cf99

元は、「password」



パスワードは暗号化されているため、本当のパスワードは分からないように思えるが、

いくつかの平文とハッシュ値のペアを記録し、ハッシュ値から平文を逆引きする。



保管パスワード:
4d808aa0dc1d615
902dda83f581bdc3

元は、「password」



サルトは、「%&54」



パスワードと別にランダムな値が付与されており、リストにない。

認証システムの実装

不正ログイン

●不正ログインの抑止

パスワードポリシー

- 最大有効期限、最小有効期限とは、同じパスワードを使い続けられる期間です。
- パスワード複雑性とは、パスワード文字列の文字種による複雑性です。推測をさせないために要求されます。
- パスワード長とは、パスワード文字列の長さによる複雑性です。推測をさせないために要求されます。
- パスワード履歴とは、過去に利用されたパスワードの履歴です。過去に使われたパスワードの再利用を抑止します。

クリッピングレベル

- クリッピングレベルとは、アクセス数や処理速度などが正常ではないことを判断するための閾値のことです。
- ログインを数回間違えた時にロックアウトするなどの何がアクションが必要となるトリガーとなる事象を指すこともあります。

パスワードの定期変更は不要？

従来はパスワードは推測されないように、定期的に変更することが一般的なパスワードポリシーでしたが、現代では“定期変更しない”ほうが主流となっています。理由は、パスワードを定期変更を要求すると、パスワード記憶の負担から、かえって簡単なパスワードに変更してしまうリスクを加味したものになります。これは、2017年、NIST SP800-63-B (<https://openid-foundation-japan.github.io/800-63-3-final/sp800-63b.ja.html>) の中で示されています。

認証システムの実装

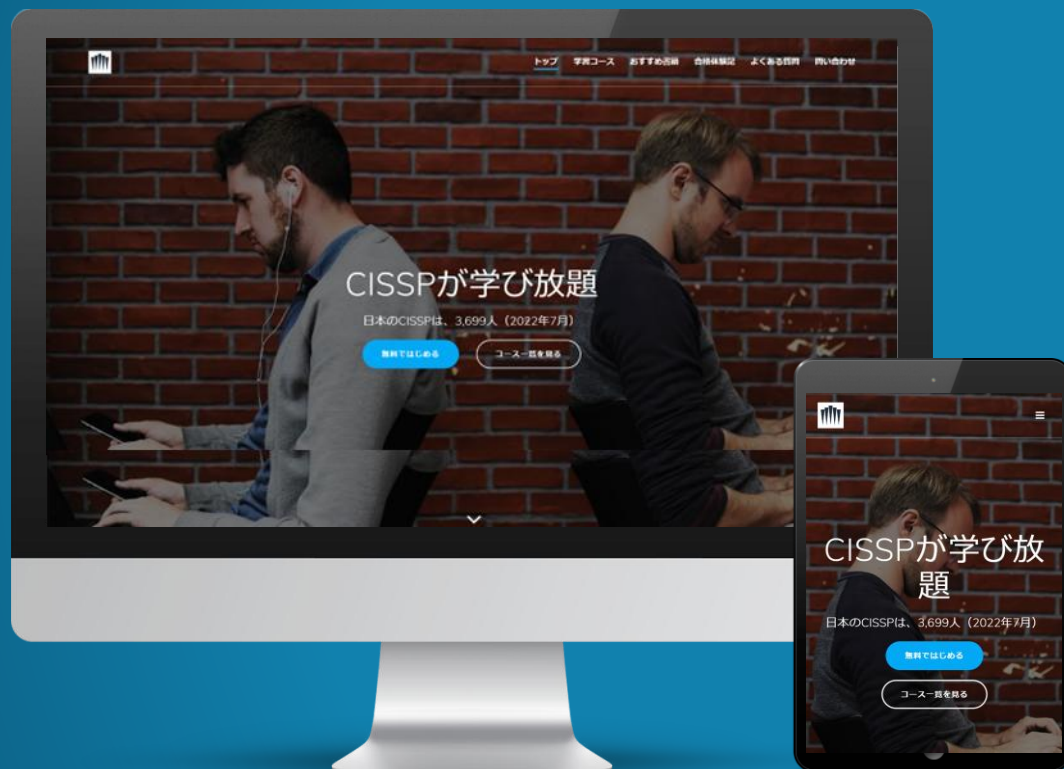
不正ログイン

● 機密情報漏洩

キーロガー

- キーロガーとは、コンピュータのキーボード操作を常時記録するハードウェアもしくはソフトウェアです。
- ソフトウェア試験時に、こういった作業をしたか記録を残しておく目的で利用されます。
- しかし、キーの入力などを記録できることで、端末で入力されたのかといった情報を取得することが出来るため、共有で利用するコンピュータにキーロガーを設置して置き、他者の情報を盗み出すなど不正に情報を取得する目的で使われるようになってしまいました。

PIEDPINの紹介



なぜセキュリティを学ぶのか

セキュリティの最も大きな敵は、人はあらゆるものに慣れ、そのリスクを考えなくなる習性にあります。セキュリティの学びを通して得られる貴重なものは、あらゆる事象に対して好奇心を持つことであり、それは目まぐるしい現代を生きるのに大いに役立つでしょう。

- EASY DESIGN
- SUPER EFFICIENT
- EVERYWHERE

PIEDPINを選ぶ理由



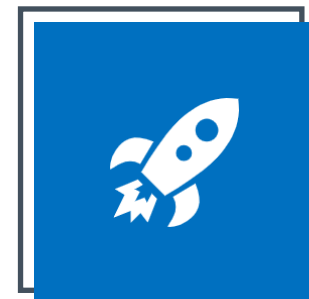
**EASY
DESIGN**

日本語で学べる



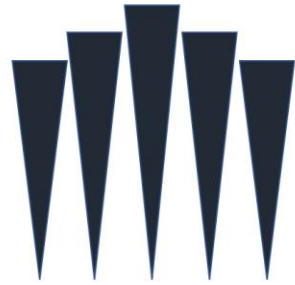
**SUPER
EFFICIENT**

わかりやすい説明



EVERYWHERE

どこからでも学べる環境



THANK YOU

Let's try CISSP!